Threat Intelligence

Threat evolution in Q1 2021

April 2021

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 4

Ransomware 5

Threats to the government sector 6

FORECASTS FOR Q2 2021 **9**

DATA LEAKS IN Q1 2021 **10**

ADVANCED THREATS IN THE FINANCIAL SECTOR **12**

FINANCIAL THREATS **15**

Malware for Android 16

Threats and malware for PC 19

RANSOMWARE **26**

STATE-SPONSORED APTS **36**

Introduction

Every quarter Group-IB releases a report on the development of high-tech cyber-crime, featuring new tendencies, emerging trends, and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the US, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by governments and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums, and accumulating information on new trends, threats, and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages, and announcements on the dark web, as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q1 saw the following APT campaigns against financial organizations:

- Group-IB specialists observed activity by the MoneyTaker group, which committed theft through AWS CBR (Russian Interbank System), after a long lull. The details of this attack cannot be disclosed at the moment.
- The Lazarus group (North Korea) continues its attacks with cryptocurrency trading platforms. In addition, a potential link between the group and the deployment of the TFlower ransomware was discovered.
- The financially motivated group FIN8 used a modified version of the POS Trojan BADHATCH in its attacks. A new wave of attacks was detected in the United States, Canada, South Africa, Puerto Rico, Panama, and Italy.

Financial threats

- The new Android banking Trojan FluBot was active in Europe (namely, Spain, Germany, Poland, and Hungary). In addition, the EventBot banking Trojan was active, with new versions observed.
- Group-IB specialists analyzed a campaign in which threat actors infect users in China, Vietnam, and Malaysia with the Android Trojan Blackloan.
- The activity of the Android banking Trojan Ghimob, which had earlier been used in attacks against users in Brazil, Paraguay, Peru, and Portugal, was low.
- The Anubis and Cerberus malware was detected in Turkey, Poland, Italy, Austria, and Chile.
- In March, a service for mobile fakes called InTheBox reported that ready-made fake pages of Canadian and Spanish banks were put up for sale. Their price is quite low, about $20 for 10 web fakes. These fakes can be used in virtually any Android Trojan with a fake window display feature. This is where the victim enters their data.
- The Android Trojan FlexNet was active in the Commonwealth of Independent States (CIS), but the number of infections has been decreasing every month.
- We have not seen any new posts about selling or renting banking Trojans for Android.
- Activity by the SystemBC malware was detected. A new panel was discovered. The main victims in it are related to India, Indonesia, and Pakistan. Detected victims include government entities, universities, and banks. In addition, SystemBC was presumably used in a REvil attack against Acer.
- Despite Qbot being increasingly used to distribute ransomware lately, in Q1 2021 it was used in attacks as a banking Trojan. As in previous periods, the targets were customers of banks in the US and Canada (judging by the Trojan's configuration files). Group-IB specialists discovered that the latest Qbot samples received a number of updates. For instance, the network protocol and security mechanisms (security checks on the server side) have been improved. A security check has been integrated to send data only one hour after a bot registers in the botnet.
- Attacks involving Gozi (ISFB) continue to be detected in Italy. Germany, where Gozi was distributed using Goootloader, is a new victim.
- The banking Trojan BBtok was active in Mexico and Spain.
- In Latin America, the Grandoreiro, Javali, Guildma and Pazera/Mekoito Trojans were also active.
- February saw attacks on ATMs in Latin America involving the old and known malware Ploutus.
- Group-IB specialists continue observing bank card JS sniffers being highly active. The number of bank cards stolen using the Poter JS sniffer decreased by 30% compared to the previous quarter. However, Group-IB specialists note that the number of infected websites and threat groups that engage in compromising online store users' bank cards continues to increase.

- Group-IB specialists discovered and analyzed the activities of three threat groups (active in Q1 2021) that performed attacks on online shops with the aim of stealing bank card data. The groups were named E1RB, FakeGraph, and SF_GATE.
- Mailouts with the RTM Trojan significantly decreased. In February – March, their number was extremely low. The RTM Trojan targeted legal entities in the CIS.
- Fall 2020 saw a large-scale operation to take down TrickBot, one of the largest botnets out there. However, the botnet is still "alive" and its latest versions have been fitted with a module for local network reconnaissance. North America, Italy, and Japan remain targeted. The focus is shifting to ransomware (Ryuk in particular).
- Gootkit is active and works with the Revil ransomware. Attacks were detected in South Korea, Germany, France, and North America.
- Mass mailouts of the IcedID Trojan were detected in English, French, and Italian.
  In addition, it was discovered that IcedID started to be used in ransomware attacks. The attack chain is as follows: IcedID -> Cobalt Strike -> REvil.
- According to the company Prevailion, Ramnit has become active again. Targets in its attacks include the medical and healthcare insurance, education, and government sectors. The purpose of the attacks is not exactly clear at the moment: it could be espionage and information theft; but it is evident that the attackers have switched from the banking sector. The attacked regions are the US, the UK, Russia, Turkey, and India.
- The banking Trojan zLoader/SilentNight was active in the US, Canada, the UK, Singapore, and Germany. The owners of the botnet use this malware not just for banking thefts but also to deliver ransomware.
- Security researchers discovered two ready-made POS Trojans: Punkey and UDPoS.
- Group-IB systems detected a sample of the banking Trojan BackSwap targeting Spain. In general, we rate the activity of this malware as low at the moment.
- Danabot became active. The fact was discovered by Proofpoint researchers, who reported that they had detected Danabot being distributed disguised as VPN clients, antivirus software, and online games offered for downloading on pirate websites.
- Group-IB specialists discovered compromised UK cards on the Entershop card shop. The database that was put up for sale contained over 30,000 cards.
- In January, Joker's Stash, one of the biggest card shops out there, announced that it would shut down.

Ransomware

Ransomware has become the biggest threat out there: we receive information about major incidents on a daily basis. Currently, we see that threat groups specifically target major companies with large revenues, which allows threat actors to demand significant ransoms for decrypting data.

This report covers only some of the incidents that have occurred.

REvil, Darkside, Cl0p, Conti, and DoppelPaymer were among the most active ransomware programs in Q1.

- Cl0p is particularly worth looking at. Attacks involving it have lately increased. The victims are companies who have used the Accellion FTA product. As such, we believe that the Cl0p threat actors are linked to the attack against Accellion or partnered with those who attacked Accellion (bought access from them). The hackers exploited four vulnerabilities in the Accellion service: CVE-2021-27101, CVE-2021-27102, CVE-2021-27103, CVE-2021-27104. This resulted in at least ten companies being compromised.
  In Q1, Cl0p had about 40 victims.

- One of the biggest Cl0p attacks was one against the information security company Qualys. Information about the attack was revealed on the Cl0p blog on March 3. On March 4, some of the data was published and on March 5 all mentions of Qualys were deleted from the attackers' website. We believe that during that time, the attackers and the victim were negotiating. It is possible that the company did not pay a ransom since on March 13 the data reappeared on the Cl0p blog.
- An attack against Eximbank, Indonesia, can be highlighted among DarkSide attacks. In Q1, about 30 companies fell victim to DarkSide.
- An attack against Acer is worth mentioning among the REvil group's major attacks; information about it was published on March 18. According to Acer, the attack only affected their office network. The threat actors demanded $50 million in ransom to not publish the data they had stolen from Acer servers. To access the network, the REvil operators used an exploit chain for Microsoft Exchange Server (ProxyLogon). In Q1, there were about 100 REvil victims.
- A HelloKitty ransomware attack was carried out against CD Projekt Red, a videogame developer. The company did not pay a ransom and the threat actors sold its data in an auction that took place on an underground forum. The lot was bought by an unknown buyer for $7 million. The lot included the source code of the REDengine game engine and the source code of released games: The Witcher 3, Thronebreaker, Cyberpunk 2077.
- On March 2, 2021, a vulnerability in Microsoft Exchange Server was discovered. Eight days after the publication of this vulnerability, a POC by a Chinese researcher was published. This prompted mass network scanning by threat actors to find and exploit vulnerable servers. One such group is DearCry, which uses the DearCry ransomware and attacks vulnerable servers.
- Conti activity is extremely high, with over 100 victim companies.
- In Q1, DoppelPaymer attacked about 40 companies.
- A new affiliate program called Babuk emerged; 15 companies have already been successfully attacked.
- Nefilim attacked ten companies in Q1.
- Avaddon attacked about 30 companies in Q1.
- The Cuba ransomware emerged in October 2020; in January 2021, a related blog was launched. The attackers have nine victims.
- February saw the arrest of the Egregor operators, which was the result of a joint effort by Ukrainian and French police. The Egregor blog was later shut down.
- Late December saw the launch of the Ragnarok blog. In Q1, the attackers had 17 victims.
- Two companies attacked by Ryuk are known: Afnor (Association française de normalisation) and the Spanish government agency for labor (SEPE).

Threats to the government sector

Q1 2021 saw the discovery of the following APT campaigns against government organizations:

- The Kimsuky hacker group (North Korea) continued their attacks using COVID-19 as a lure as well as a document related to the beginning of the Biden administration's term. In addition, the threat actors attacked a senior researcher at the Center for Korean Studies at the Far East Institute of the Russian Academy of Sciences.
- Since May 2019, Earth Wendigo, a previously unknown group, has been conducting a campaign against several organizations, including government organizations, research institutions and universities in Taiwan. The main attack method used by the threat actors is injecting JavaScript backdoors to a webmail system.

- Presumably APT-C-36 (South America) is carrying out a campaign against government institutions and private companies in Colombia. The hackers are particularly interested in the energy and metallurgical industries.
- In addition to semiconductor manufacturers, Chimera (China) were interested in the aviation industry: the hackers stole passengers' personal data (Passenger Name Records).
- APT31 (China) is suspected of conducting attacks against Western countries, including Germany. The hackers target ministries, government authorities, political organizations, and funds. In addition, it came to light that APT31 had used an exploit for Windows vulnerability CVE-2017-2005 three years before the Shadow Brokers leaked the tool.
- Patchwork (India) carried out attacks against China by sending out spear-phishing emails with a malicious attachment with an EPS script that exploits vulnerability CVE-2017-0261.
- The BITTER group (India) deployed its malware on the legitimate website of a technology provider and distributed it in South Asia. In addition, the group exploited a zero-day vulnerability, CVE-2021-1732, for seven months and remained unnoticed. Microsoft fixed this bug only in February 2021.
- After a five-year lull, the group Lebanese Cedar (Lebanon) resumed its attacks. The threat actors used open-source hacking tools to scan the Internet for unpatched Atlassian and Oracle servers. The group was interested in the telecommunications sector.
- The StrongPity hackers (Turkey) continued their attacks, this time using trojanized utility Partition Find and Mount.
- Another supply-chain attack was carried out by unknown hackers as part of Operation NightScout. The hackers gained access to the servers of the developer of the Android emulator NoxPlayer and pushed trojanized updates that delivered malware.
- The Confucius group (India) used new Android spyware families, named Hornbill and SunBird.
- For four years, Domestic Kitten (Iran) has been engaging in cyber espionage, with at least 1,200 people affected. The group has used the FurBall malware, which is based on commercially available monitoring software called KidLogger.
- The BlackTech hackers (China) added new malicious shellcode dubbed BendyBear to their arsenal. Neither the distribution vector nor the victims are known.
- The TA428 group (China) attacked East Asian defense and aviation organizations, such as ones in Russia and Mongolia, using nccTrojan.
- BabyElephant (India) attacked targets in Pakistan. The group used a lure in the form of documents related to a national engineering company under the Ministry of Industries and Production of Pakistan.
- In late 2020, cybersecurity experts discovered a hacker group called LazyScripter, which had been active since 2018 and remained unnoticed for a long time. The threat actors target airlines that use the BSPLink software made by the International Air Transport Association (IATA), it was reported.
- The TA413 group (China) attacked Tibetan organizations worldwide using FriarFox, a malicious Firefox browser extension that stole Gmail and Firefox data and then downloaded the ScanBox Trojan on infected systems.
- The APT41 hackers (China) were highly active. They were observed using new Trojans; in particular, RedXOR, FunnySwitch, and Spyder. They also attacked energy companies in India as part of a campaign named RedEcho and a telecommunications company in Central Asia as well as an oil company and a construction equipment company both based in East Asia.

- The SideWinder group (India) continued its attacks against Pakistani government officials.
- The Gamaredon hackers (Russia) continued their malicious activity against Ukraine and in their attacks used both well-known spear-phishing techniques and older methods such as using trojanized applications. For instance, the legitimate program Zoom was installed on the victim computer together with a malicious module.
- Security specialists discovered a new group called HAFNIUM (China), which exploited zero-day vulnerabilities in Microsoft Exchange over the course of several months and attacked many organizations worldwide.
- Lazarus (North Korea) continued their attacks on defense and aviation organizations worldwide, including using the ThreeNeedle Trojan. The biggest event was the group's attack targeting security researchers working on vulnerability research and development at different companies and organizations.
- The Mustang Panda threat actors (China) took an interest in telecommunications companies in Europe, South East Asia, and the US (namely, the 5G technology) and carried out a malicious campaign called Operation Dianxun.
- The DarkHalo group's new malicious programs were discovered: Sunspot, used for installing the Sunburst backdoor, and tools for later campaign stages: GoldMax, Sibot, and GoldFinder.
- A new group called Spiral (China) was discovered. The attack on SolarWinds involving the Supernova web shell (which was carried out at the same time as the supply-chain campaign by the DarkHalo group) is attributed to Spiral.
- Security specialists discovered a campaign against Japan by A41APT. The campaign started in March 2019 and has a strong connection with the APT10 group (China).
- The Cloud Atlas group (Russia) continues its campaign that started in 2019. The threat actors target the CIS and Western Europe.
- A new tool of the Turla group (Russia) was discovered. It was named IronNetInjector.
- Downdelph malware samples by the APT28 group (Russia), presumably used in attacks against Kazakhstan, were discovered.
- Details about an attack involving the Clambling malware were revealed. The APT27 group (China) is presumably behind the attack.
- A sample of the Donot Android Trojan (presumably India) disguised as the Omegle application was discovered.
- The APT35 group (Iran) carried out targeted attacks during Christmas and New Year holidays against think tank members, a political research center, university professors, journalists, and environmental activists from the Gulf States, Europe and the US.
- At the beginning of the quarter, information emerged about a campaign conducted by the BlackEnergy group (Russia) targeting the French IT monitoring software manufacturer CENTREON, which resulted in the breach of several French entities.

The MuddyWater group (Iran) carried out attacks against targets in government entities, academic institutions, and the travel industry in Azerbaijan, Saudi Arabia, Israel, Bahrain, and the UAE.

Forecasts for Q2 2021

- Ransomware will remain the number one threat in terms of both the number of attacks and financial damage. We already see that ransoms demanded by threat actors reach $100 million. Unfortunately, even the largest companies with competent information security specialists and newest security technologies cannot fully protect themselves against this threat.
- Credit card sniffers will remain a relevant threat. Group-IB specialists continue to detect infections on many websites. We have also seen a rise in the number of groups that use this type of tool in their attacks.
- Qbot, IcedID, and Gootkit will be employed together with ransomware instead of being used as banking Trojans.
- As a result, the number of attacks involving banking Trojans will continue to decrease.
- Still, attacks involving banking Trojans will continue in Latin America. Grandoreiro, Javali, Guildma, and Pazera/Mekoito are relevant for the region.
- FluBot, Anubis, Cerberus, and Eventbot will be the most active Android Trojans. They mostly target Europe.
- The number of zLoader infections in the US and Canada will either grow or remain at the current level.
- We believe that MoneyTaker may commit new thefts through AWS CBR (Russian Interbank System) in banks in Russia.
- We believe that due to the shutdown of the biggest card shop out there, Joker's Stash, one of the remaining card shops will try to occupy that niche on the underground market.

Data leaks in Q1 2021

- In March, a dump with the data of former clients of the service WeLeakInfo was published on RaidForums, an underground forum. The dump includes personal and corporate data, including email addresses, names, billing addresses, last four digits and expiration dates of credit cards, IP addresses, order history, IP addresses, and phone numbers.
  WeLeakInfo was an underground service that sold access to 12.5 billion accounts collected from 10,000 leaks. The service was shut down in early 2020 as part of a coordinated action by the FBI and law enforcement agencies of Northern Ireland, the Netherlands, Germany, and the UK.
- It came to light in January that the source code of mobile apps and internal tools developed and used by Nissan North America had been leaked online. The leak occurred because the company's IT specialists made a mistake in configuring a Git server, leaving its default username and password combination (admin/admin).
- On February 26, 2021, a part of a backup copy of a database belonging to American Exchange Bank was published on xss, a forum, in the Microsoft SQL Server 2017 format. The author of the forum thread could not open it themselves. On March 2, 2021, a thread about selling the data of American Exchange Bank's US clients was created by the same author, Lucifer6. The full dump contains data on about 16 million clients.
- On February 25, 2021, dumps with data on customers of VPN services for Android were put up for sale on RaidForums; in particular, GeckoVPN, SuperVPN, ChatVPN, and FlashVPN. The full dump contains data on about 21 million customers of these services.
- On February 14, 2021, the database of Astoria Company was put up for sale on RaidForums. The data tables contain names, email addresses, phone numbers, SSNs, dates of birth, IP addresses, and driving license numbers. In total, the tables contain data on about 100 million users.
- On February 6, 2021, a database with information on Malaysian voters was put up for sale on the RaidForums forum. The database contains names, NRIC information, and addresses of Malaysian citizens. In total, the data tables contain information on about 10 million people.
- On February 27, 2021, a database of Oxfam participants with 1.7 million records was published on RaidForums. The data tables include participants' names and addresses.
- On February 12, 2021, a database with information on patients in French hospitals was published on RaidForums. The data tables contain patients' names, phone numbers, email addresses, and addresses. The database contains 500,000 records.
- In February 2021, the Philippine company Cashalo reported about unauthorized access to their customer database archive. The database, which contains information on 3.3 million users of the service, was later put up for sale on an underground forum by a user with the username creepxploit. For each user entry, the database includes an email address, password hash, and phone number.
- In late 2020, a major online gun shop, Guns.com, suffered a data leak affecting 400,000 users of the service. On March 9, 2021, the guns.com database was published on RaidForums. The compromised customer data includes names, email addresses, and password hashes.
- On February 23, 2021, a database of the streaming service Zee5 was published on RaidForums. The leak involves data on 9 million users, including email addresses, password hashes, and full names.
- In March 2021, threat actors obtained a database of the Japanese company Urban Research. The stolen database contains information on over 400,000 users, including email addresses, password hashes, and names.

Advanced threats in the financial sector

333

APT name	Regions attacked	Operation start
Lazarus	Global	2018

In February 2021, the US Cyber Command published details about a version of the AppleJeus malware, Ants2Whale and related IOCs used by the North Korean government in AppleJeus operations, which were discovered in August 2018.

Ants2Whale, discovered in October 2020, is legitimate-looking cryptocurrency trading software that is marketed and distributed by a company and website — Ants2Whale and ants2whale[.]com respectively — that appear legitimate.

The website states that in order to download, a user must contact the administrator as their product is “premium package." The domain ants2whale[.]com had a legitimately signed Sectigo Secure Sockets Layer (SSL) certificate, which was “Domain Control Validated” just as all previous AppleJeus domain certificates.

An OSX program from the Ants2Whale site is an Apple DMG installer. The OSX program does not have a digital signature and will warn the user of that before installation. As all previous versions of AppleJeus, the Ants2Whale installer appears to be legitimate and installs Ants2Whale in the /Applications/Ants2whale[.]app/Contents/MacOS/Ants2whale folder and a program named Ants2WhaleHelper also in the /Library/Application/ Support/Ants2WhaleSupport/ folder.

An OSX sample was contained within Apple DMG installer "Ants2Whale.dmg." Ants2Whale is likely a copy of an open-source cryptocurrency wallet application. When ran it loads a legitimate looking program which is fully functional.

Ants2WhaleHelper is similar to variants of AppleJeus. The Ants2WhaleHelper program contains the custom C++ "Barbeque" class for network communication.

In January 2021, Group-IB specialists discovered a similar cryptocurrency trading program, which was called CreAI Deck.

In addition, it was found that the MATA backdoor (aka Dacls) had been used for deploying the TFlower ransomware. The hackers called themselves the “TFlower group.” Since at least May 2019, MATA operators have continuously utilized new servers, with over 150 IP addresses linked to the frameworks’ C&C. Analysis indicates that the group has possibly deployed over 150 C&C servers over time, with the latest one identified on February 4, 2021.

The TFlower ransomware campaign was covered by several technology news websites between September and November of 2019. However, since then very little information has been made public about the ransomware group or its operations.

Analysis of encrypted machines revealed that the ransomware executable was deployed and executed using the MATA backdoor. Specifically, the path to the ransomware executable was found within the MATA backdoor memory space on the encrypted machines. This raises the possibility that the Lazarus Group is either the group behind TFlower or has some level of collaboration with it.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. Specialists have established that the group’s members are from North Korea.

APT name	Regions attacked	Operation start

FIN8	USA, Canada, South Africa, Puerto Rico, Panama, Italy	2016

Specialists at Bitdefender discovered new versions of the POS malware BADHATCH (v2.12–2.14). The latest version abuses a legitimate service called sslp.io to thwart detection during the deployment process, using it to download a PowerShell script.

Badhatch is responsible for the initial attack phase: its task is to research the victim's network. It can also install PoSlurp, a program designed to intercept data of payment cards that pass through POS terminals. Badhatch is a unique piece of malware designed by FIN8 actors specifically for their own ends.

Financial threats

Malware for Android

Threat name	Detection	Regions attacked
FluBot	January 2021	Spain Germany Poland Hungary

This banking Trojan was discovered in early 2021. Its main function is to show fake login screens on top of other applications. As such, FluBot collects victims' electronic banking credentials and payment card details.

The malware is distributed through mass SMS spamming. Once the victim's device is infected, threat actors can upload the contact list to their C&C server and send spam SMS messages from there. Links in the messages usually lead to hacked websites, where FluBot operators place their malware in the form of APK files.

FluBot does not have full control over the device unless the user provides it with access to the Accessibility service. If the rights are obtained, the malware can execute commands and simulate touching the screen, while remaining invisible to the owner of the device. As a result, FluBot is capable of intercepting and blocking app notifications, setting itself as the default SMS app, using USSD, making phone calls, and stealing contact lists. In addition, access to Accessibility allows the Trojan to display phishing screens over other legitimate applications.

FluBot has lately been distributed in Poland, Germany, and Hungary disguised as a FedEx application and in Spain disguised as DHL.

Threat name	Detection	Regions attacked
EventBot	March 2020	Italy UK Spain Switzerland France Germany

This malware targets users of over 200 financial applications, mostly Spanish and Italians ones. EventBot functionality includes interception of input data and SMS messages, execution of web injects, and use of autofill features through Accessibility Service.

The malware is usually disguised on victim mobile phones as Adobe Flash Player, Microsoft Word, or YouTube.

February 2021 saw the discovery of a new EventBot version, which involves encryption of sent requests using the ChaCha2 algorithm. The key is calculated based on the execution of certain operations with a set of values for an Android device ID and several hardcoded constants.

Threat name	Detection	Regions attacked
Cerberus	April 2020	Global

In April 2020, a user with the username ANDROID made a post on XSS.is, an underground forum, about renting out an updated version of the Android banking Trojan Cerberus.

The updated Cerberus can send and intercept SMS messages, show web fakes to the user, record keystrokes (keylogger), launch applications installed on the device, bypass security restrictions and antiviruses, create fake PUSH notifications, and open URLs in the browser.

This malware is an updated version of the Cerberus Android bot created in June 2019. Later in 2019, the source code was published free of charge for premium users of one forum. Posts with the Trojan's source code continue to be occasionally published to this day (March 2021), which means that many threat actors have been using it.

In Q1 2021 mass attacks were discovered in Turkey, Poland, Italy, Austria, and Chile.

Threat name	Detection	Regions attacked
Blackloan	May 2020	China Vietnam Malaysia

Group-IB specialists analyzed a campaign in which threat actors infect users in China, Vietnam, and Malaysia with the Android Trojan Blackloan.

This malware can intercept SMS messages and have remote access to infected devices. Threat actors created fake resources disguised as bank websites and distributed malicious APK files from them.

Threat name	Detection	Regions attacked
Anubis	October 2019	Global

This malware is distributed through Google Play services disguised as legitimate software. It is also spread through phishing pages imitating those of banks. In Russia, there have been detections of phishing pages disguised as those of Russian banks and used for distributing the malware.

Anubis's main functionality includes web fakes, USSD requests, interception and sending of SMS messages, and remote access to target devices. Anubis helps obtain full control over an infected device by automatically disabling Google Protect.

In Q1 2021, it was discovered that Anubis was distributed in Turkey. In addition, an application called QR Scanner was discovered on Google Play; it was used to distribute Anubis. More than 5,000 people downloaded this app, but specific countries where the victims are located are not known.

Threat name	Detection	Regions attacked
FlexNet	2014	Russia

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access the privileges.

On command from the C&C server, the application can:

- Change the C&C server address
- Send an SMS message to a specified number
- Send bulk SMS messages with a specified text
- Forward SMS messages to a remote server
- Reply to SMS messages and delete them to conceal the fact from the user
- Run USSD requests
- Schedule commands: configure a command template for new bots for a particular operator and country

In addition, FlexNet had phishing dialog boxes added to its functionality. They are disguised as popular applications and designed to obtain the victims' bank card details. The following fake dialog boxes were detected:

AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Threats and malware for PC

Threat name	Detection	Regions attacked
E1RB threat group	January 2021	Global

The first attacks by the E1RB threat group were discovered in January 2021. Over the time it has been active, the group has infected 13 online shops. The group's distinct characteristic is the use of special obfuscation mechanisms that depend on the current time. Another distinct feature is generation of unique malicious code samples on the fly for every new visitor of an infected website. Visitors to the websites from Italy, Pakistan, the US, Hungary, the UK, and the Netherlands fell victim.

Threat name	Detection	Regions attacked
FakeGraph threat group	April 2020	Global

Throughout its activity, the FakeGraph group has infected a total of 54 online stores, 11 of which were infected in Q1 2021. In each infection, the group uses a unique malicious code injection scheme, which complicates analysis and detection of the initial infection point: an initial injection is made into existing JavaScript code of a website, the injected code then loads and decodes next-stage code designed for card theft. Among the websites infected by the group are online stores operating in the US, the UK, Spain, Turkey, Australia, Brazil, Canada, Estonia, Hong Kong, Ireland, South Korea, the Netherlands, Chile, China, France, Greece, and Romania.

Threat name	Detection	Regions attacked
SF_GATE threat group	April 2020	Global

The SF_GATE group started its activity in April 2020. The threat actors have been actively using fake payment forms, injected into website code when payments are made, which makes it possible to easily intercept bank card details entered by buyers. The group infected a total of 158 sites, most of which (122) belong to the American company MerchLabs. Other victims of the threat group include visitors to online stores in France, Spain, the Netherlands, Portugal, Switzerland, Belgium, Austria, Italy, the UK, India, Canada, Australia, Denmark, Greece, Israel, Sweden, and Ireland.

Threat name	Detection	Regions attacked
zLoader/Silent Night	November 2019	USA Canada UK Singapore Germany

This Trojan was put up for sale in late 2019. At the end of Q1 2020, it started being used in the wild. It is mostly distributed through mailouts with a macro-containing Excel file, which loads Zloader.

Group-IB specialists also analyzed several Zloader panels mostly targeted at users in the US.

As at the end of Q1 2021, the panels have over 5,000 bots overall. Statics in terms of countries is as follows: the US, Canada, the UK, Singapore, Germany, Australia, and India.

Threat name	Detection	Regions attacked
Trickbot	2016	North America Europe Japan Australia

Trickbot is a banking Trojan that uses techniques similar to those of Dyre. It is distributed through email spam. Lately, however, it has often been distributed using Emotet. Since 2020, in addition to being used as a banking Trojan, the malware has been used in ransomware attacks.

In 2020, Trickbot was fitted with new features:

- Bypassing UAC in Windows 10 (it was previously available only for Windows 7) to deliver malware to numerous machines in the target network.
- Use of Windows 10 ActiveX to execute malicious macros.
- Module for using hacked machines for RDP brute-force attacks.
- In May 2020, Palo Alto Networks discovered that Trickbot's propagation module called nworm had been updated. Infections caused through it leave no artifacts in the victim's domain controller, which disappear after a reboot or shutdown. It is run from RAM. In addition, unlike the previous module (mworm), the new module transfers Trickbot's executable file in encrypted form.
- In October, a new Trickbot feature was discovered, which enables threat actors to tamper with UEFI/BIOS. The new module checks the SPI controller to see if BIOS write protection is enabled. The module has not been witnessed modifying the firmware itself, though it already contains code to read, write, and erase firmware. The new module has not yet been detected in use in actual attacks.
- In February 2021, a new component was added. It performs local network reconnaissance. Named masrv, the component incorporates a copy of the Masscan open-source utility in order to scan local networks for other systems with open ports. The idea behind masrv is to drop the component on newly infected devices, send a series of Masscan commands, let the component scan the local network, and upload the scan results to a Trickbot C&C server.

Malicious mailouts distributing Trickbot in Q1 2021 were in English.

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Italy Germany

Gozi/ISFB is a well-known banking Trojan. Group-IB specialists have lately been observing the use of Gozi 2.X and Gozi v3.

The malware's main features include:

- MITB (Man-In-The-Browser) attacks using web injects
- Theft of user accounts from infected devices
- Execution of CMD commands
- Download of files to an infected device and their execution
- Extension of functionality through the download of additional modules from the C&C server
- Video recording

Q1 2021 saw many phishing mailouts in Italian targeting Italian users.

Attacks were also detected in Germany, where Gozi was distributed using Goootloader.

Threat name	Detection	Regions attacked
SystemBC	2018	India, Indonesia, Pakistan, Philippines, Egypt, Germany, Brazil, Ethiopia, Nigeria, Lesotho, Morocco, Spain, Serbia

The past quarter saw activity of the SystemBC malware. A new panel was discovered. The main victims in it are related to India, Indonesia, and Pakistan. Detected victims include government entities, universities, and banks. In addition, SystemBC was presumably used in REvil attacks against Acer (March 2021) and Union Bank of Nigeria (February 2021).

Group-IB specialists detected the SystemBC malware being highly active in India, Indonesia, Pakistan, Turkey, the Philippines, Vietnam, and other countries. The analyzed SystemBC panel contained over 4,000 unique bots.

The SystemBC malware uses SOCKS5 proxies. It uses a beacon on the infected machine and establishes new proxy connections between the C&C server and remote hosts. The proxy connections are RC4-encrypted. The malware receives commands through HTTP and creates new proxy connections as instructed. It is sold on exploit[.]in, an underground forum, under the name sock5 backconnect system. SystemBC is usually used for hiding malicious traffic associated with other malware. It was detected that the malware was loaded and used for this purpose for Danabot, Smokeloader, and ISFB (Gozi) as well as employed in ransomware attacks (REvil, Ryuk).

Threat name	Detection	Regions attacked
Gootkit	2014	South Korea Germany France North America

We have not seen any activity from the Gootkit banking Trojan since October 2019. However, in December 2020 it reappeared on the radar. Security specialists discovered a malicious campaign targeting users in Germany. The campaign involved both the Gootkit Trojan and the Revil ransomware, which may suggest that the Gootkit operators decided to shift their focus to working with ransomware.

In this campaign, the threat actors hack WordPress sites and utilize SEO poisoning to display fake forum posts to visitors. These posts pretend to be questions and answers with a link to fake forms or downloads.

When the user clicked on the link, they downloaded a ZIP file containing an obfuscated JS file (Gootloader loader) that installed either the Gootkit malware or the REvil ransomware. The same attack method had previously been used by REvil operators in September 2019, around the same time that Gootkit disappeared.

In Q1 2021, attacks involving Gootkit were detected in South Korea, Germany, France, and North America.

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	France Italy

IcedID was first detected in late 2017. The malware can be used to steal financial information and launch targeted attacks. IcedID is mostly distributed using Emotet but also through phishing emails with a malicious macro that downloads and launches IcedID.

IcedID has a modular architecture and many features of Zeus, including web injects, data theft, and the ability to inject code into other processes. One of the bot's distinct characteristics is its ability to deploy a proxy server on an infected machine and redirect all Internet traffic using that server.

In addition to banks, IcedID currently attacks e-commerce businesses. In either case, threat actors' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

In May 2020, Group-IB specialists analyzed a new version of IcedID (21st one), in which configuration files were hidden in PNG images. In earlier versions (e.g., 12), the PNG file only contained the main module.

In mid-2020, it was discovered that the Valak loader started to be used to distribute IcedID.

In Q1 2021, IcedID was active and the decoy documents containing it were in English, French, and Italian. Its targets have not been identified.

In addition, it was discovered that IcedID started to be used in ransomware attacks. The attack chain is as follows: IcedID -> Cobalt Strike -> REvil.

Threat name	Detection	Regions attacked
Qbot	2009	USA, Canada

Qbot (QakBot) emerged in 2009 and has since been regularly improved. Qbot is a modular multithread Trojan that can steal banking data, digital certificates, authentication tokens, and cookies as well as function as a keylogger, backdoor, and SOCKS proxy; it also has antivirus evasion features. Qbot is designed to target businesses and steal money from bank accounts. The Trojan is distributed as a worm by self-replicating through shared drives and removable media.

In 2020, the Qbot operators, as well as those of other banking Trojans, decided to shift their focus toward distributing ransomware. In particular, the Qbot operators worked with the Egregor ransomware.

The configuration file of the latest detected samples of Qbot contains the following targets:

Chase
BB&T
Citizensbank
Capitalone
Firstcitizensonline
Suntrust
Wellsfargo
Frostbank
Scotiabank
Bank of America
Bank of Montreal
Royal Bank of Canada
Citibank
Bank of the West
EastWest Bank
Fifth Third Bank
HSBC
JP Morgan
Mandt Bank
The PNC Financial Services Group
TDBank
Usbank
Amegybank
National Bank of Arizona
Vectrabank
Zionsbank
Schwab
Desjardins
Scotiabank

Group-IB specialists discovered that the latest Qbot samples received a number of updates. For instance, the network protocol and security mechanisms (security checks on the server side) have been improved. A security check has been integrated to send data only one hour after a bot registers in the botnet.

Threat name	Detection	Regions attacked
Grandoreiro	2017	Latin America, Europe

This malware has been known since 2017. Since April 2020, there has been a rise in its distribution against the backdrop of the COVID-19 pandemic.

Group-IB specialists obtained a list of targets from a sample of this malware and established that banks in Brazil, Spain, the UK, Peru, and Germany were among the targets.

Below is a list of targets from the malware configuration files in Q1 analyzed by Group-IB specialists:

Banco do Brasil
Santander
Caixa
Banco Safra
Banco do Nordeste
Sicredi
Agibank
Bradesco
Banorte
Citibanamex
Scotiabank
Bankinter

BBVA
Liberbank
ACTIVOBANK
NOVO BANCO
Banco Azteca
Cecabank
HSBC UK
Natwest
Barclays UK
Banco Estado
Citi Private Bank
Commerzbank
Deutsche bank
EVO Banco
MicroBank
MiBanco

Threat name	Detection	Regions attacked
BBtok	November 2020	Mexico Spain

This Trojan is distributed through phishing emails with a malicious .lnk attachment. After the attachment is launched, a PowerShell script is executed, which launches the payload.

Following this, the Trojan launches a backdoor module on the infected machine. Remaining undetected, it can receive commands from the C&C server: create a fake banking-related window for the victim to enter their data in.

The malware also replaces the file "winmm.dll" in the system directory to establish persistence. In addition, the malware deletes registry entries of mainstream antivirus software to make the antivirus software invalid.

Banks that the Trojan can mimic when generating fake windows include:

Santander
BanBajio
ScotiaBank
AFIRME
Banregio
Banco Azteca
Multiva
Inbursa
HSBC
Banorte
CitiBanamex
BBVA

While in Q4 2020 attacks were only detected in Mexico, in Q1 2021 the malware started to spread across Latin America as well as in Spain.

Threat name	Detection	Regions attacked
Javali	2017	Latin America

This banking Trojan emerged in 2017. It targets banking customers and cryptocurrency owners.

Below is an up-to-date list of targets:

Banco do Brasil

Banco Bradesco
Santander
Banco Sicredi
BRB Banknet
Banco Inter
Banese
Banco MUFG Brasil S.A.
Banco ABC Brasil
Banco Daycoval
Banco Mercantil
Banco Paulitsa
Banco Safra
Caixa
Banco BMG

Threat name	Detection	Regions attacked
Guildma (Astaroth)	2017	Brazil Spain

This Trojan was discovered in 2017. In the second half of 2019, it started attacking users mostly in Brazil. At the height of the pandemic, it was distributed primarily through COVID-19–related email spam. Later, the mailouts were mostly disguised as banking related. In Q1, attacks were detected in Brazil and Spain.

Threat name	Detection	Regions attacked
Pazera/Mekoito	2015	Latin America Spain

This Trojan has been known since 2015. Its features include performing backdoor functionality, taking screenshots of the victim's desktop, restarting the system, limiting access to legitimate banking resources, and exfiltrating data from browsers.

In Q1 2021, it was mostly active in Spain.

Ransomware

Threat name	Detection	Regions attacked
Babuk	January 2021	USA Germany Spain Norway Canada Austria Portugal

In January, a blog with this ransomware's victims was launched and in March, the start of an affiliate program was announced on underground forums.

In January – March, the following companies were attacked:

Boca Group International Inc
Human Gesellschaft für Biochemica und Diagnostica mbH
MECOL INSTALACIONES ELECTRICAS SL
Serco Group
Alentec & Orion AB
Schauer Agrotronic GmbH
.wtv Württemberger Medien GmbH & Co. KG
FRULACT - INDÚSTRIA AGRO-ALIMENTAR, S.A.
Morgan Steel
EUROCONTROL SA
Icon Parking Systems
TenAsys
PetCare Insurance Agency

Threat name	Detection	Regions attacked
Egregor	September 2020	Global

In February, several Egregor operators were arrested in Ukraine as a result of a joint effort by Ukrainian and French police. No Egregor ransomware attacks have been seen after the arrest. In addition, the Egregor blog was shut down.

Below is a list of companies attacked in Q1:

IndiGo
TransLink
Pegasus Group
Clyde, Ferraro & Co., LLP
Little Rock Convention & Visitors Bureau
Rand City of Independence
Baxter, James & Rose, LLP
Mesquite Independent School District
RMB PRODUCTS
DSC Logistics stad USA

Threat name	Detection	Regions attacked
DarkSide	November 2020	USA Germany UK Netherlands Canada France Japan Indonesia Italy Brazil UAE

In March, an affiliate program was relaunched due to the ransomware's update to version 2.0. In January – March, the following companies were attacked:

OMV System France
Rechtsanwälte Staab & Kollegen
I-D Foods Corporation
OneDigital
Echo USA L.L.C.
Heussen Rechtsanwaltsgesellschaft mbH
Inter-State Studio & Publishing Co.
ISSA
Wonderbox
Pénélope Groupe
Copel Comercializacao S/A
Sierra Meat
AIDA-America
Xcoal Energy & Resources, LLC
A.L.A. SPA
Amico Group
Discount Car and Truck Rentals
KOMORI CORPORATION
SEGAFREDO ZANETTI AUSTRALIA PTY LIMITED
Fownes Brothers & Company, Inc.
CovalentWorks
Mirion Technologies Inc.
Aaronson Rappaport Feinstein & Deutsch, LLP
Guess
Bock Hatch Lewis & Oppenheim LLC
Lembaga Pembiayaan Ekspor Indonesia
TPI Corp
I. W. T. DEESIDE LIMITED
Stone Pigman Walther Wittmann, LLC
Grupo Segura
Jacoby & Jacoby
Payne & Fears LLP
PEKAES SP ZOO

Swift Real Estate Partners LLC

Threat name	Detection	Regions attacked
Cl0p Ransomware	February 2019	Germany South Korea Canada India Austria Netherlands Singapore Spain

Below is a full list of companies attacked in January – March 2021:

Singtel Singapore
Mvtec Software
Polyvlies
Amey
American Bureau of Shipping
Fugro
SoftwareAG
Elandretail
Novabiomedical
NFT Distribution
Technische Werke Ludwigshafen
ExecuPharm
Danaher Corporation
TAM International
Allstate Peterbilt Group
Jones Day
CSA Group
Bombardier
RaceTrac Petroleum
Pentair
STERIS
CGG SA
Qualys, Inc
TRANSPORT FOR NSW
Campbell Trial Lawyers
Flagstar Bank
CSX Corporation
Now Health Group, Inc
Wright Medical Group N.V.
Kinze Manufacturing Inc
M Moser Associates Ltd.
EDAG Engineering Group AG
The7stars UK ltd
University of Colorado
University of Miami
Postlethwaite & Netterville
Navigant Consulting Inc
Shell

Threat name	Detection	Regions attacked
Conti	February 2020	Germany South Korea Canada USA France Taiwan Australia India UK

An attack against the US law firm Jones Day is among major Conti attacks.
Below is full list of companies attacked in January – March 2021:

Newmark Grubb|CBI
White Management Corp.

G&D Integrated
Norwescap Holding Company Inc
Weslaco Independent School District
The Fayette County Emergency Management Agency
Scotch Plywood Company
Supply New England
Ashland Technologies
Creccal Investments Ltd
Sunny Hills Management Co
Legacy Farms LLC
Gastroenterology Consultants
MEDTRON Software Intelligence Corporation
Metroplex Cabinets
Stark Metal Sales Inc
Gesgapegiag
Murchison & Cumming
Schick Civil Construction Ltd
The Abaco Club on Winding Bay
Gulf Copper
Fattorie Garofalo Soc. Coop. Agricola
Legacy Farms LLC
Orcas Naturals
Scottish environment protection agency
Vander-Bend Manufacturing
Christensen O'Connor Johnson Kindness
The Smith Company Inc
Carl Belt Incorporated
Ashley Stewart, Inc
Rampart Brokerage Corp
ColorPoint Print
Ventilabec Inc
The Brevard County Sheriff
Penn Emblem
Valley Wide Cooperative
Netcom Kassel
Conestoga Meat Packers Ltd
Allegheny Intermediate Unit
JB Martin
Westside Door Inc
Georgetown County South Carolina Government
Nocona General Hospital
Prima Frutta
Doug Hollyhand Realty Inc
Pace Center for Girls, Inc
RE/MAX Kelowna
Munoz Trucking, Inc
Corporate Turnaround
County of Clearfield PA
Tirrena Scavi
Syndiant
Total Fitness
Trudeau Corporation Inc
Blue Projects Inc
H-E-B Center at Cedar Park
Innovsource
TL Machine
Caster Concepts
SMC Industries
SkyeTec
Morris Costumes
Diamonds international
Rehoboth McKinley Christian Health Care Services
Island Pacific
The International Society of Automation
MNA Media
Willdan Group
B Green Wholesale
Integrated Service Solutions Limited
PFF Group UK
MVTec Software GmbH
Holly Poultry LLC
Custom Made Meals
United Capital Corp
White Glove Placement
C.A.T. Inc
J Rosenthal and Son
ROGASA
Party Rental LTD
PartsBase Inc
Lauzon Flooring
DDSG Logistics
Neil Kelly Company
Axxess International Inc
Nienkamper Furniture & Accessories Inc
KeyColour Dyesis
Area Diesel Service, Inc
Ajax TOCCO Magnethermic
Jacquet Metals Group
Applied Consultants Inc
Execu Search Group
Contraste Lighting
Berger Levrault
BVA Group
Nenplas Company
H-E-B Center at Cedar Park
Exide Technologies
LivaNova PLC
Health Aid Of Ohio
Capmar Insurance Services
SUPREME Corporation
D.A. Blodgett St. John’s
New England Finish Systems
Amaroo Village

SET Enterprises Inc
Pitt Plastics LLC
Groupe-Upperside
Cross City Church
Advantech
Lincoln County, Washington
Buddy Gregg RV's & Motor Home

Threat name	Detection	Regions attacked
DoppelPaymer	June 2019	Global

An attack against Kia Motors America, an automobile manufacturer, is among the most noticeable DoppelPaymer attacks. The hackers demanded a ransom of $20 million.

Below is a full list of companies attacked in January – March:

Promutuel Fédération de Société Mutuelles d'Assurances Générales Life and Health Insurance
Tescor Inc
Westech Systems Inc
Urbaser SA
Jacobsen Construction Co., Inc
Yamagata Prefectural Federation of Societies of Commerce and Industry
Georgia Crown Distributing Co.
City of Novato, California
PratoAllarmi SRL
ANA Global LLC
Green Rubber-Kennedy AG
Financial Debt Recovery Limited
Hyundai Motor America + KIA
Cuyahoga Metropolitan Housing Authority
Jazzware. Inc
ANA Global LLC
Planning and Development Service of Kenton County / PDSKC
Azusa Police Department
American Home Craft Inc
Telmar Group Inc
Vuteq Corporation
TSI Consumer Goods GmbH
Nif Group, Inc
Kuwata Glass Co., Ltd
Sasegur SI
TFI International
United Tactical Systems, LLC / WY Technology / Pepperball Technologies
CNIJ Inc
Nederlandse Organisatie voor Wetenschappelijk Onderzoek
Alphacam GmbH
Florida Studio Theatre
Seigniory Chemical Products Ltd
SKC Communications
Morgan County
Press-Seal Gasket Corporation
Ensinger Industries, Inc
Manutan International S.A.
Soflog / GCA SUPPLY LOGISTICS
Lynch Automotive Inc.
Illinois Gas Company / Utility Safety & Design, Inc
Westech Systems Inc
A123 Systems LLC
Jazzware. Inc
Financial Debt Recovery Limited
Homeperf
Cuyahoga Metropolitan Housing Authority

Threat name	Detection	Regions attacked
Ragnarok	January 2020	Italy Canada Germany Bolivia Argentina

		Colombia Ecuador Spain Portugal USA

Below is a full list of companies attacked in January – March 2021:

CDN Controls Ltd
Porter Ramsay LLP
InvoDane Engineering Ltd
Kingsdale Advisors
Oliver Stoewer
MORESCHI SPA
EURAPO SRL
EI colegio Juan de Valdés
SEMANTICA SRL
MEDICAIR SUD SRL
Immundiagnostik AG
LABORATORIO ANALISI VALDES SRL
WIMEX Agrarprodukte Import und Export GmbH
Bolivia Petroleo y Gas Consultores y Servicios S.R.L.
Kellhuber GmbH
Teknomast srl

Threat name	Detection	Regions attacked
Nefilim	March 2020	USA Brazil France Mexico India Italy Australia Canada Germany England Jamaica Sri Lanka New Zealand

Below is a full list of companies attacked in January – March 2021:

Colliers International Group Inc
BEIJER REF ITALY SRL
Charm Sciences, Inc
Placon Corp.
GNP Seguros
Grimmway Enterprises, Inc
Spirit Airlines, Inc

Vitro, S.A.B. de C.V.
Atlanta Allergy & Asthma
Elliott Group
Cascade Engineering, Inc.
Unitex Textile Rental Services
Elliott Group

Threat name	Detection	Regions attacked
Avaddon	June 2019	Global

In early February, the ransomware's decryptor was published, which is why by the end of February the ransomware was updated.

Below is a full list of companies attacked in January – March 2021:

Marolles-en-Brie
Finalyse
Biorep Technologies, INC
MK-Technik
Allanasons Ltd
American Heart of Poland Inc
PT Asuransi Bintang Tbk
Vaughn Concrete Products , INC
Universal Accounting Services INC
SVI Assurances
Mundo Fertil SA
Elite Software , Inc
Bee Line Logistics, INC
Keith Machinery Corp
Hardy Buoys Smoked Fish Inc
FBL Advogados
Somerset ISD
Groupe Qualinet Inc.
The Capital Medical Center
Mullins Food Products Inc
JFC International (Europe)
Carnegie Wave Energy
Grand Power Systems
Veriha Trucking Inc
Party Rental LTD
Prefeitura Municipal de Saquarema
CELL Foods Inc.
Futurimplants
Cashmag
Doré Law Group P.C
Omni Manufacturing, Inc.
AnlecR&D
La compagnie du SAV
Siscon
AlohaABA
Bridgeway Senior Healthcare
Sovrin Plastics Limited
Zhuhai Languan Electronic Technology Co., Ltd

Threat name	Detection	Regions attacked
RansomExx	March 2020	USA Brazil Australia Chile France Indonesia Italy

Below is a full list of companies attacked in January – March 2021:

St. James Parish Credit Union
Ultrapar Participacoes S/A
Vistra Group Ltd.
Indura SA
Soluzioni Infrastrutturali Telefoniche ed Elettriche S.p.A.

CalAmp Corp.
PT Pertamina

Threat name	Detection	Regions attacked
Mount Locker	July 2020	USA Canada Germany France England Peru Sweden Taiwan

Below is a full list of companies attacked in January – March 2021:

Homeland Title Company
Transtar Industries Company
Faps Inc
The Wasserstrom Company
Geotech Engineering and Testing Inc
Mersen SA
Laboratorios SMA S.A.C.

Threat name	Detection	Regions attacked
REvil	April 2019	Global

Below is a full list of companies attacked in January – March 2021:

Ribstein & Hogan
Preferred Home Care
Ghilotti Bros. Inc
Weiland Trucking Co., Inc.
UCAR
Reese , Pyle , Drake & Meyer , P.L.L
General Insulation Company
Ottawa Cooperative Association Inc
Blazona Concrete Construction, Inc
Trigano SA
Banco Inmobiliario Mexicano, S.A.
Reno & Zahm LLP
Cockram Construction
Corbally, Gartland and Rappleyea, LLP
Southern Concrete & Construction, Inc.
Jacobs Vanaman Agency Insurance
Resort Lifestyle Communities Inc
SHELLY & SANDS, Inc.
Dairy Farm International Holdings Limited
J & B Distributing Co.
Malcolm Drilling Company, Inc.
D.M. BARONE SPA
Southern Arkansas University
R.S. Hughes Company, Inc.
MJS Packaging Inc
Standley Systems
Wallin Hester, PLC
Union Bank of Nigeria PLC
McCabe & Ronsman
Acer Inc.
Milsoft Utility Solutions Inc
Summit Credit Union

Threat name	Detection	Regions attacked

Cuba	November 2019	USA Canada

Below is a full list of companies attacked in January – March 2021:

The Squamish Nation
Automatic Funds Transfer Services Inc
Otr Capital, LLC

Threat name	Detection	Regions attacked
Pysa	October 2019	USA

Below is a full list of companies attacked in January – March 2021:

Virgin Islands Port Authority
Blackhawk Mining, LLC
Affton School District
Millersville University

Threat name	Detection	Regions attacked
Ragnar Locker	December 2019	USA

Below is a full list of companies attacked in January – March 2021:

Cornerstone Building Brands
Kaye Bassman International Corporation

State-sponsored APTs

APT name	Regions attacked	Operation start
Kimsuky	South Korea, USA, Russia	December 2020

The Kimsuky group has recently carried out attacks, in which it altered a private stock investment messenger program to conduct supply-chain attacks.

The messenger program was produced in the form of an NSIS (Nullsoft Scriptable Install System) installation program. NSIS is a script-based installation system for Windows, and it is an installation program creation tool provided by Nullsoft, which is known to have made Winamp.

Two types of command were found this time; “wmic.exe” connects to a specific FTP server and downloads additional command files.

The additional files are executed based on a VBS command and create OracleCache, PackageUninstall, and USODrive in the %ProgramData% subfolder. Then, connection to the server frog.smtper[.]co is established and additional commands are executed.

In addition, the library “Office365__” is registered in the task scheduler and a trigger is set that repeatedly executes every 15 minutes under the name “activate” in the path [Windows\Office].

The operating program used here is “usopub.vbs” created in the OracleCache folder, which also tries to connect to the FTP address periodically through the wmic command.

The threat actors then screen the infected person based on the collected primary information and send an additional remote access tool (RAT).

In addition, the Leaf Smtper email sending program is registered on the server used by the attackers.

Security researchers also found a malicious document files that used the same technique. This file manipulates the screen like a protected document and prompts you to click the Enable Content button.

If the user clicks on the Enable Content button, communication with the FTP server (search.greenulz [.]com) designated by the threat actor is performed through the same wmic os get command included inside.

Later, in January 2021, the hackers used a document that purported to be for the issuance of a donation receipt to respond to COVID-19 in 2021. In time for the year-end settlement season, this attack was subtly disguised as an email request for a donation receipt from a specific private relief association in Korea.

A compressed file named “2021 Corona 19 Response_Donation Certificate.zip” was attached to the email.

There are 2 files inside the compressed file:

- “2021 Corona 19 Response_Donation Certificate.pdf”
- “Application form for issuance of large donation receipt _ Form _ Individual.xlsb”

The .xlsb file induces the user to click on the Enable Content button. The victim is shown a normal document. However, in the background, the computer connects to the FTP server specified by the attackers and attempts to execute additional commands.

When analyzing the commands included in the Excel sheet, the equals sign (=) was used in the first cell character to be regarded as a formula, and the C&C server string was used in an obfuscation method in which each character was put in a separate cell.

When all the obfuscated strings are interpreted, the threat actor connect to the FTP server designated by them through the regsvr32.exe command and a call through the Script Component Runtime argument is performed.

With this routine, arbitrary malicious scripts in URL (FTP) addresses can be executed, and further attacks are possible at any time depending on the intent of the attackers.

Later, another series of attacks was discovered. The attacks involved what was disguised as a questionnaire on the inauguration of the Biden administration and the foreign and security policies. The first time a malicious DOC file is executed, a false English message that pretends to be an Office update to allow malicious macro functionality was displayed, prompting the user to click on the Enable Content button. Clicking on this button leads to the execution of malicious commands included in the macro.

The malicious macro function hidden inside collects information about the antivirus software installed on the computer, communicates with the C&C server, and exchanges information. It then attempts to hijack and download additional malicious files. The payload-featured malicious file (pay1.down) that is additionally attempted to be downloaded is a typical spyware activity that involves collecting user information and transmitting it to the attacker.

Security experts' monitoring of threats posed by the Kimsuky group revealed an attempted email hacking attack against a senior researcher at the Center for Korean Studies at the Far East Institute of the Russian Academy of Sciences in Moscow.

The threat actor created a specific short URL address using the Short URL generator service. It seems that the actual address below was used in the attack. It seems that the short URL address surl[.]me/zsu7 was used as an email link, and when the recipient clicks on the link, a login screen purporting to be the Russian web service rambler.ru is displayed.

The elaborately crafted fake login screen has an email address, ludmila_hph@rambler.ru. Performing a search reveals that it is the account of a real person.

The person is a senior researcher at the Center for Korean Studies at the Far East Institute of the Russian Academy of Sciences in Moscow. Their main research areas are North Korea's economy and foreign economic relations, inter-Korean economic relations, and economic relations between Russia, North Korea, and South Korea.

Kimsuky (also known as Velvet Chollima and Thallium) is a hacker group believed to be based in North Korea. The group has been actively attacking entities in the South Korean territory since 2010, but has lately been expanding the geographical scope of their attacks.

APT name	Regions attacked	Operation start
Earth Wendigo	Taiwan, Hong Kong, Tibet, Uyghur region	May 2019

Security experts have discovered a new campaign that has been targeting several organizations — including government organizations, research institutions and universities in Taiwan — since May 2019, aiming to exfiltrate emails from targeted organizations via the injection of JavaScript backdoors to a webmail system that is widely-used in Taiwan. With no clear connection to any previous attack group, the experts gave the new threat actors the name Earth Wendigo.

As an initial attack vector, the group used spear-phishing emails containing obfuscated JavaScript code meant to load malicious scripts from an attacker-controlled remote server.

These scripts were designed to steal browser cookies and webmail session keys, propagate the infection by appending code to the victim's email signature, and exploit a cross-site scripting (XSS) vulnerability in the webmail server for JavaScript injection.

The exploited XSS vulnerability resides in the webmail system's shortcut feature and allows the attackers to add a shortcut with a crafted payload, replacing parts of the webmail system's page with malicious JavaScript code.

The experts reported that the XSS vulnerability was fixed in January 2020, meaning that only organizations that have not updated to the latest version of the webmail server remain exposed.

Should this method fail, the attackers' script registers malicious JavaScript code to the server's Service Worker (a programmable network proxy inside the browser), so that it could intercept and manipulate HTTPS requests, hijack login credentials, and add malicious scripts to the webmail page.

After performing the XSS injection or adding code to the Service Worker, which ensures that the malicious script is constantly loaded and executed, the attackers proceed to exfiltrate emails by establishing a WebSocket connection to an injected JavaScript backdoor.

The backdoor reads emails on the server and sends their content and attachments to the attacker's WebSocket server.

In addition to targeting webmail servers, Earth Wendigo also uses Python malware compiled as Windows executables, which were found to be shellcode loaders for code likely from Cobalt Strike. Some of the Python samples are backdoors that request additional Python code from the C&C server.

APT name	Regions attacked	Operation start
APT-C-36	Colombia	2020

In 2020, security researchers observed several attacks exclusively targeting Colombian entities. At the time of writing, these attacks are ongoing and are focused on both government institutions and private companies, especially in the energy and metallurgical industries.

ESET uncovered an ongoing surveillance campaign, dubbed Operation Spalax; they linked at least 24 different IP addresses in use in the second half of 2020 to the wave of attacks against Colombian entities. These IP addresses are probably compromised devices that the hackers use as proxies for their C&C servers.

Attacks against organizations start in a typical way — phishing emails. The topics range from notifications to attend a court hearing and freezing of bank accounts to a mandatory COVID-19 test. Some of the emails purported to be from the Office of the Attorney General or the National Directorate of Taxes and Customs.

The emails have a PDF document attached containing a link to RAR archive. If the victim downloads the archive, which is hosted on OneDrive, MediaFire, or another cloud storage service, a file contained in it launches malware. The target has to manually extract the file and execute it for the malware to run.

The hackers use variety of packers; but their purpose is to have a remote access Trojan (RAT) running on the victimized computer by injecting it into legitimate processes. The malicious campaign involves a total of three RATs. All of them are sold on the black market and none were developed by the Operation Spalax organizers.

The first Trojan, Remcos, can be bought on an underground forum for as little as $58. The second, njRAT, is known for using Pastebin as a C&C infrastructure. The third Trojan, AsyncRAT, is an open-source remote administration tool. The experts did not find any one-to-one relationship between droppers and the Trojans but noted that NSIS droppers mostly drop Remcos, while Agent Tesla and AutoIt packers typically drop njRAT.

The researchers did not find enough clues to identify the threat actors. However, they found some indication regarding APT-C-36.

APT-C-36 (aka Blind Eagle) is a suspected South America espionage group that has been active since at least 2018. The group is mainly interested in the secret information of major companies and government entities. Malicious emails are the threat actors' main attack vector. To hide email sender IP addresses, the group has used proxies and VPN services.

APT name	Regions attacked	Operation start
Chimera	Taiwan, Asia	2017

Security specialists discovered that the Chimera group's activities were not limited to attacks on Taiwanese semiconductor manufacturers, as previously assumed. It turned out that the hackers were as interested in the aviation industry; moreover, not only in Asian countries. In some cases, the attackers successfully hid inside the networks of compromised companies for up to three years, avoiding detection.

While the attacks on the semiconductor industry were aimed at stealing intellectual property, the attacks on the aviation industry had a very different purpose: the hackers stole passengers' personal data (Passenger Name Records).

Typically, Chimera attacks began with the collection of credentials leaked to the public as a result of any incidents. This data was then used to carry out targeted attacks such as credential stuffing and password spraying. That is, the attackers tried different usernames and tried to use them with the same simple, easily guessed password in the hope of finding a poorly protected account.

Such attacks by Chimera were aimed at specific employees of the targeted companies in order to, for example, compromise their mail. Having penetrated into someone else's mailbox, the hackers looked for data that would help them gain access to corporate systems (Citrix, VPN, and so on).

In the internal networks of the victim companies, the attackers took their time and usually deployed Cobalt Strike, which they used to move laterally across the network and hack as many systems as possible. In this way, the attackers searched for IP addresses and information about passengers. The detected data was regularly uploaded to various cloud services, including OneDrive, Dropbox and Google Drive (such traffic is usually not suspicious and is not blocked).

APT name	Regions attacked	Operation start
APT31	Germany, Norway, Finland	April 2020

APT31 attacks are currently directed against political targets in Western countries. They include ministries, government authorities, political organizations and funds.

At the moment, APT31 mostly focuses on reconnaissance and attack preparation activities, which include sending tracking emails to possible targets and scanning network infrastructures:

- Tracking emails give the impression of being legitimate by imitating contacts the addressee knows and/or using topics that are relevant to the addressee. The emails contain tracking pixels or links that collect technical information about the target system.
- Scanning activities are particularly aimed at the services and infrastructure components of a target organization that can be accessed from the Internet. This is to be understood in particular as classic port or vulnerability scanning. The focus is on the standardized ports (0-1023). In addition to various standard ports for web use and file transfer, ports of services that enable remote access may also be affected.

In addition, researchers at Check Point noticed that APT31 used an exploit for Windows vulnerability CVE-2017-2005 three years before the Shadow Brokers leaked the tool, together with other exploits and data stolen from the NSA.

The Chinese hacker's exploit is called Jian. It is a copy of the EpMe exploit, which had been developed and actively used by Equation Group (whose activity experts have long linked to the NSA) between 2014 and 2017. When the Shadow Brokers stole the NSA's data and tools and published them in the public domain, EpMe also became available to the public. However, it had fallen into the hands of the Chinese group much earlier.

APT31 managed to somehow obtain samples of all versions of the NSA's exploit: Jian was built using the 32-bit and 64-bit versions of EpMe. Check Point believes that the information could have been acquired by the Chinese hackers in one of the following ways:

- Captured during an Equation Group network operation on a Chinese target
- Captured during an Equation Group operation on a third-party network that was also monitored by the Chinese APT
- Captured during an attack on an Equation Group infrastructure.

APT31 is characterized as an actor specialized on intellectual property theft, focusing on data and projects that make a particular organization competitive in its field. Based on available data, security specialists believe that APT31 conducts network operations at the behest of the Chinese government.

APT name	Regions attacked	Operation start
Patchwork	China	January 2021

Recently, in January 2021, security researchers observed the Patchwork APT cyber espionage group targeting China with a malformed document named "Chinese_Pakistani_fighter_planes_play_war_games.docx". It is suspected that the attack is executed in the form of spear-phishing emails with malicious attachments. The experts discovered that the attack involved techniques such as exploitation of long-closed vulnerabilities and social engineering campaigns.

The discovered sample is a malcrafted Microsoft document with an EPS script that exploits the CVE-2017-0261 vulnerability. CVE-2017-0261 is Microsoft Office remote code execution vulnerability in which the software fails to properly handle objects in the memory. It allows the attacker to install and run additional payloads on the victim machine.

The malcrafted EPS scripts drop a Patchwork payload file named "MSBuild.exe." This is a VC+ compiled file with encrypted data, which decrypts and loads the Windows API function dynamically during runtime.

Interestingly, the payload file has a hardcoded C&C server IP, URL and User agent. Upon execution, this file creates a mutex named assssszxxzcccjddddddccccdjjjddssdfgredf to mark its presence on the victim machine and avoid multiple executions of itself.

The malware payload starts collecting information from the victim system such as computer name, comspec, home directory, logon server, the number of processors, and much more using Windows API such as GetComputerNameA, GetTempPath, and GetConsoleWindow. The Patchwork payload logs keystrokes, screenshots, and running processes with the date and time and stores them in a file named "TPX498.dat" in %Temp% folders. The malware then uses a custom encryption logic to encode data and send it to the C&C server over HTTP.

The Patchwork APT campaign has autostart capabilities by adding the payload files in the %Startup% folder of the victim machine so that it can execute on every reboot of the system.

The Indian hacking group Patchwork (also known as Dropping Elephant, Chinastrats, APT-C-09, Monsoon, Confucius, Viceroy Tiger, EHDevel, Hangover, ZINC EMERSON, and Manul) has been active since at least 2015 and has been attacking organizations in industries connected with diplomatic missions and government entities for the purposes of espionage and information theft.

APT name	Regions attacked	Operation start
BITTER	South Asia	May 2020

Cybersecurity experts have recently discovered that the BITTER group may have compromised the official website of a technology provider in South Asia (RASTEK Technologies) and deployed malware on it.

After the sample runs, a software installation interface will be displayed, and then the user will be prompted that there is a problem with the installation package and that it cannot be installed, which is aimed at confusing the victim.

The next stage is the release of "dsparse.exe," and addition to a task schedule with the name \Windows\Wininet\CheckCacheBuffer, which will download and execute hxxp://rastek[.]net/HjlkYR/chkupdate.msi. The link, however, was inaccessible at the time of the analysis.

The released "dsparse.exe" is a loader of the .NET platform. After execution, a timer is first created to communicate with the server. The malware then obtains the current computer user name, system version, system digits, MAC address, and other information. Finally, it adds a self-start item to the registry through PowerShell.

When the communication timer function is triggered, it will first detect whether the MAC address information has been successfully obtained. If it is not successful, the malware will try to obtain the information again, and then use the decryption function to determine the communication server address. Unfortunately, no subsequent payload was obtained.

In addition, BITTER used a zero-day vulnerability (tracked as CVE-2021-1732), which was categorized as an elevation of privilege bug in Win32k. According to security researchers, the exploit for CVE-2021-1732 was compiled in May 2020 and was designed to target the 64-bit Windows 10 1909 operating system (OS), but later testing revealed that the bug also posed a threat to the latest 64-bit Windows 10 20H2 OS.

The BITTER group has been active since at least 2015 and is believed to represent Indian interests. BITTER APT campaigns primarily target China, Pakistan, and Saudi Arabia. The group's arsenal includes a similarly named remote access Trojan called BitterRAT and a downloader malware family called ArtraDownloader.

APT name	Regions attacked	Operation start
Lebanese Cedar	USA, UK, Israel, Egypt, Saudi Arabia, Lebanon, Jordan, UAE, Palestine	2020

After a five-year gap, the Lebanese Cedar threat group (formerly known as Volatile Cedar) was caught performing malicious activities again. The group has been linked to intrusions at telecom operators and Internet service providers in the US, the UK, Israel, Egypt, Saudi Arabia, Lebanon, Jordan, the Palestinian Authority, and the UAE. The hacking campaign discovered by the cybersecurity firm Clearsky started in early 2020 and lasted for nearly a year.

According to a new report, security specialists identified at least 250 web servers hacked by the Lebanese Cedar group. The threat actors' aim was to gather intelligence and steal databases containing sensitive data.

The attacks followed a simple pattern. Lebanese Cedar operators used open-source hacking tools to scan the Internet for unpatched Atlassian and Oracle servers, after which they deploy exploits to gain access to the servers and install web shells to access the internal systems of the targeted companies.

For their attacks on servers, the hackers used vulnerabilities such as:

- CVE-2019-3396 in Atlassian Confluence
- CVE-2019-11581 in Atlassian Jira
- CVE-2012-3152 in Oracle Fusion

Once they gained access to these systems, the attackers deployed web shells, such as ASPXSpy, Caterpillar 2, Mamad Warning, and an open-source tool named JSP file browser (which can also function as a web shell).

On internal networks, the attackers deployed a more powerful tool named Explosive remote access trojan (RAT), which is specialized in data exfiltration and which has until now been exclusively used by the Lebanese Cedar group.

The researchers also said that attackers made mistakes in their operation and often reused files between intrusions. This allowed the experts to track the attacks across the globe and link them to the Lebanese Cedar group.

Since late 2012, a carefully orchestrated attack campaign called Lebanese Cedar (aka Volatile Cedar) has been targeting individuals, companies and institutions worldwide. This campaign, led by a persistent attacker group, has successfully penetrated a large number of targets using various attack techniques, and specifically, a custom-made malware implant codenamed Explosive.

Volatile Cedar is an advanced hacker group believed to be linked to the Hezbollah Cyber Unit.

APT name	Regions attacked	Operation start
StrongPity	-	November 2020

While tracking the activities of the StrongPity APT team, security experts found that the group currently carries out attacks using trojanized Partition Find and Mount software utility and an updated C&C infrastructure.

The high-level execution flow of the StrongPity infection is as follows:

1. It starts with the APT actor using a watering hole attack or phishing email to deliver the trojanized Partition Find and Mount software utility to the victims.
2. The trojanized installer drops multiple malware components in the %temp%\ndaData folder along with configuration files.
3. The Launcher component is responsible for executing the Exfiltrate module, which runs another File searcher component.
4. The File searcher component enumerates system drives and looks for target files with specific extensions. The list of extensions is embedded in the StrongPity payload.
5. If the files are found on the victim's machine, they will be copied into a temporary ZIP archive. After the completion of adding the files to the archive, it splits into hidden .sft encrypted files.
6. These hidden .sft files are sent to the C&C server through a POST request and are then removed from the disk based on a further C&C command. The Exfiltrate module has commands to delete the .sft files after they are sent to the hacker C&C server.

Upon the execution of the trojanized installer, it extracts and drops encrypted payloads, which are part of its resource section. StrongPity payloads such as the Launcher & Persistence component, Exfiltration &

Command Execution module, and the File Searcher component are extracted and dropped in the %temp%\ndaData folder. The malware payload creates a mutex named "thUseiGpkMkPkFYrIOvKN" to mark its existence in the victim's system.

The Exfiltrate component has a hardcoded C&C URL, decoded in the memory. As seen in earlier variants, "Parse_ini_file.php" is used as part of layer 1 communication and functionality to get commands from the C&C server.

PROMETHIUM is a group of hackers believed to be from Turkey. The group, which was active as early as 2012, is also known as StrongPity and APT-C-41. Information about this threat group was first published in October 2016 with details about the group's attacks against users in Belgium and Italy. In 2018, the threat actors shifted their focus to a different region and targeted Turkish telecommunications companies in order to attack hundreds of users in Turkey and Syria.

APT name	Regions attacked	Operation start
Operation NightScout	Global, Hong Kong, Sri Lanka, Taiwan	September 2020

Unidentified hackers gained access to the servers of the developer of the Android emulator NoxPlayer and tampered with the download URL of NoxPlayer updates to deliver tainted updates. The threat actors behind the attack pushed a series of tailored malicious updates that resulted in malware being installed on the devices of a handful of selected victims. At the moment, only five victims were identified in Hong Kong, Sri Lanka, and Taiwan.

The Android emulator developed by the Hong Kong company BigNox is often used to launch online games on computers running Windows and macOS. BigNox says that over 150 million users in more than 150 countries have their product, NoxPlayer, installed.

According to cybersecurity specialists, the NoxPlayer developer's network was compromised in September last year. Explicitly malicious activity was uncovered on January 25. The researchers believe that the attackers' end goal was to collect information about certain gamers who use BigNox's product. The campaign was dubbed Operation NightScout.

Analysis revealed that the threat actors compromised BigNox's file server (res06.bignox.com) to host malware on it. They also likely compromised the API that NoxPlayer uses to receive information about updates.

The researchers identified three variants of the payload distributed under the guise of NoxPlayer updates. One of them is an undocumented backdoor, which can execute commands to delete, download, and upload files.

The second variant is made up of several files and disguised as the Windows utility Sandboxie, which is used for launching applications in a sandbox. The malware was found to be a variant of Gh0st, which is usually used in APT attacks for espionage purposes. Both malicious programs were distributed from the compromised BigNox server in September.

The threat actors later started using their own server with fake updates. The server distributed another well-known surveillance tool — PoisonIvy. This RAT used to be highly popular among APT groups too.

APT name	Regions attacked	Operation start

Confucius	Pakistan, Kashmir, USA, Russia, India, UAE, Ukraine, Poland, Iran, Spain, France, UK, Italy, Serbia, Indonesia, Kazakhstan	2018

Security researchers published information on two recently discovered Android spyware families, named Hornbill and SunBird and employed by the Confucius APT group.

The two families were used for spying on the personnel linked to Pakistan's military, nuclear authorities, and Indian election officials in Kashmir.

Both malware families can target a broad range of data for exfiltration, including call logs, contacts, device metadata (such as phone numbers, IMEI/Android IDs, device model, manufacturer), Android version, geolocation, images from external storage, and WhatsApp voice notes.

Both malware families are also able to perform the following malicious actions:

- Request device administrator privileges
- Take screenshots, capturing whatever the victim is currently viewing on their device
- Take photos with the device camera
- Record environment and call audio
- Scrape WhatsApp messages and contacts via accessibility services
- Scrape WhatsApp notifications via accessibility services

SunBird has a more extensive set of malicious capabilities than Hornbill. It attempts to upload all data it has access to at regular intervals to its C&C servers. Locally on the infected device, the data is collected in SQLite databases which are then compressed into ZIP files as they are uploaded to the C&C infrastructure. The malware can download attacker-specified content from FTP shares and run arbitrary commands as root, if possible.

Hornbill targets a limited set of data; the malware only uploads data when it initially runs and the upload occurs when data monitored by Hornbill changes.

The malware closely monitors the use of resources on the infected device, collects hardware information, logs location data, and monitors external storage for ".doc," ".pdf," ".ppt," ".docx," ".xlsx," and ".txt" documents.

The experts say that the operators behind Hornbill are extremely interested in users' WhatsApp communications; Hornbill also records WhatsApp calls by detecting active calls by abusing Android's accessibility services.

Based on the locale and country code information regarding infected devices and exfiltrated content, the experts believe that SunBird may have roots as commercial Android surveillanceware. The data includes information on victims in Europe and the United States, some of which appear to be targets of spouseware or stalkerware.

Confucius is a pro-India APT group active since 2013. It has been mainly focused on Pakistani and other South Asian targets. For the past several years, however, it also switched to mobile malware, with the first Android surveillanceware ChatSpy being observed in 2018. The group may be linked to another Indian group, Patchwork.

APT name	Regions attacked	Operation start

Domestic Kitten	Global, Iran, USA, Pakistan, Turkey, UK, Afghanistan, Uzbekistan	2017

According to a new post, Domestic Kitten has been conducting widespread surveillance for the past four years, launching at least 10 separate campaigns and maintaining a target list of 1,200 individuals, at a minimum.

At present, four active campaigns have been recorded, the most recent of which appears to have begun in November 2020 and is ongoing. The victims are located across the world including in Iran, the US, Pakistan, and Turkey.

The APT uses mobile malware dubbed FurBall. The malware is based on commercially-available monitoring software called KidLogger, and according to the researchers, "it seems that the developers either obtained the KidLogger source code, or reverse-engineered a sample and stripped all extraneous parts, then added more capabilities."

FurBall is spread through a variety of attack vectors including phishing, websites, Telegram channels, and via SMS messages containing a link to the malware. The malware utilizes a variety of disguises to trick the victim into installing it; such as being packaged as VIPRE mobile security, masquerading as a news outlet app, acting as repackaged legitimate mobile games, app stores, restaurant services, and wallpaper applications.

Once installed on a target device, FurBall is able to intercept SMS messages, grab call logs, gather device information, record communication, steal media and stored files, monitor device GPS coordinates and more. FurBall sends the collected information to C&C servers that have been used by Domestic Kitten since 2018. Linked IP addresses were found in Iran.

Domestic Kitten (aka APT-C-50) has been active since at least 2016 and specialists believe the Iranian government is behind it. The attacks affect Android mobile devices and are carried out with the aim of cyber espionage against people that pose a threat to Iranian interests.

APT name	Regions attacked	Operation start
BlackTech	Taiwan	August 2020

Security researchers shared info on a new polymorphic and “highly sophisticated” piece of malware dubbed BendyBear, linked to a hacking group with known ties to the Chinese government.

BendyBear is also “one of the most sophisticated, well-engineered and difficult-to-detect samples of shellcode employed by an Advanced Persistent Threat (APT)," a report says.

Although discovered in August 2020, there is no information on the infection vector used to deploy it on targeted systems or any potential victims.

The malware has features and behavior that strongly resemble those of the WaterBear malware family, active since at least as early 2009. WaterBear is connected with the Chinese group BlackTech.

This shellcode's only function is to be used to download other malicious payloads from attacker-controlled C&C servers. Cyber spies who use BendyBear in their operations will load it onto compromised devices immediately after gaining access to the machine following exploitation.

"At 10,000+ bytes, BendyBear is noticeably larger than most, and uses its size to implement advanced features and anti-analysis techniques, such as modified RC4 encryption, signature block verification, and polymorphic code," the researchers said.

Among BendyBear's long list of features and capabilities, the experts say that it:

- Transmits payloads in modified RC4-encrypted chunks. This hardens the encryption of the network communication, as a single RC4 key will not decrypt the entire payload.
- Attempts to remain hidden from cybersecurity analysis by explicitly checking its environment for signs of debugging.
- Leverages existing Windows registry key that is enabled by default in Windows 10 to store configuration data.
- Clears the host's DNS cache every time it attempts to connect to its C&C server, thereby requiring that the host resolve the current IP address for the malicious C&C domain each time.
- Generates unique session keys for each connection to the C&C server.
- Obscures its connection protocol by connecting to the C&C server over a common port (443), thereby blending in with normal SSL network traffic.
- Employs polymorphic code, changing its runtime footprint during code execution to thwart memory analysis and evade signaturing.
- Encrypts or decrypts function blocks (code blocks) during runtime, as needed, to evade detection.
- Uses position independent code (PIC) to throw off static analysis tools.

BlackTech (also known as Circuit Panda, Radio Panda, and T-APT-03) is a Chinese cyber espionage group operating against targets in East Asia, particularly Taiwan, and occasionally Japan and Hong Kong. Based on the mutexes and domain names of some of their C&C servers, BlackTech's campaigns are likely designed to steal their targets' technology.

APT name	Regions attacked	Operation start
TA428	East Asia, Mongolia, Russia	March 2019

Security researchers continued discovering information about the TA428 hacker group and its tools. A new blog post described nccTrojan (also known as MsmRAT), which is a RAT used by TA428, similar to Tmanger. The experts observed multiple cases of nccTrojan being used in attacks on East Asian defense and aviation organizations, such as ones in Russia and Mongolia.

nccTrojan can be executed in the early stages of an attack (opening an RTF generated by the Royal Road RTF Weaponizer) or after a more advanced horizontal deployment. However, unlike other RATs (SPIVY and Cotx RAT) used by TA428, the number of observations is extremely small, and little was known until now. According to the experts' research, the Trojan was developed at least around March 2019 and confirmed to be used in November 2020.

There are likely to be two major versions of nccTrojan: v1 and v2. There are more subdivided minor versions within each, for example v1 has v1.6 and v1.7, but there is not much difference in their implementation. However, the implementations of v1 and v2 are quite different and at first glance they are not considered to be the same malware family. The values of the commands used are very different from v1, but the functionality of the commands is roughly the same.

The experts confirmed that v1 implements basic commands as a RAT such as file operations, remote shell, and process operations. Unlike v1, v2 is used when the attack is more advanced (after horizontal deployment, you already have system privileges). In addition, the startup method is different from v1, and v2 works by being registered with the service by the installer.

The Chinese progovernment group TA428 has been active since 2013. The threat actors have targeted a number of government agencies in East Asia overseeing government information technology, domestic affairs, foreign affairs, economic development, and political processes.

APT name	Regions attacked	Operation start
BabyElephant	Pakistan	January 2020

The recently captured BabyElephant attack methods are mainly designed to deliver compressed packages containing blank RTF documents used for a social engineering cover and LNK files containing malicious links. The filenames of the compressed packages, RTF files, and LNK files are all related to Heavy Mechanical Complex Ltd, which is a national engineering company under the Ministry of Industries and Production of Pakistan.

The attackers use the name of the LNK file to induce the victim to click to execute the LNK file. When the LNK file is executed, the second-stage malicious HTA script will be executed through the built-in tool MSHTA of the Windows system, and the second-stage malicious HTA script will be connected.

The attackers' malicious payload hosting server downloads the WRAT malware and creates a scheduled task to launch WRAT at regular intervals. Analysis of WRAT revealed that the Trojan not only has a backdoor function, but also has the ability to steal files from mobile disks, infect newly connected storage devices, and move laterally to expand the scope of infection.

Even though the researchers note that the group's attack methods are in some ways similar to the attack methods used by the Indian groups SideWinder and Bitter, there are significant differences in attack details and Trojans used.

BabyElephant (aka GroupA21) is an APT group from the direction of the South Asian subcontinent (presumably India). The group's attacks can be traced back to July 2017. Its main targets are governments, military, defense, foreign affairs, nuclear energy, finance, education, telecommunications, and other departments of South Asian countries such as Pakistan, Bangladesh, Sri Lanka, and Maldives.

APT name	Regions attacked	Operation start
LazyScripter	Canada	2018

In late 2020, cybersecurity experts discovered a hacker group called LazyScripter, which had been active since 2018 and remained unnoticed for a long time. The threat actors target airlines that use the BSPLink software made by the International Air Transport Association (IATA), it was reported.

The researchers say that LazyScripter attacks usually start with phishing activity aimed at individuals looking to immigrate to Canada for a job, airlines, and the IATA.

The threat actors' infrastructure is still active and the group continues to evolve by updating its toolsets. For instance, the hackers' latest activity involves the use of the freely available Octopus and Koadic malware. Both were delivered through malicious documents and ZIP archives that contained embedded objects (VBScript or batch files) and not macro code commonly seen in phishing attacks.

The experts also found other examples where LazyScripter used other RATs common to multiple hacking groups: LuminosityLink, RMS, Quasar, njRat, and Remcos.

The phishing emails analyzed by the specialists used the same loader to drop both Koadic and Octopus. The loader was named KOCTOPUS. Before it, the threat actors used Empoder, a loader for PowerShell Empire.

In addition, it was noted that LazyScripter hosted its toolsets on GitHub. The specialists found three accounts linked to LazyScripter. Two of them (LIZySARA and Axella49) were deleted in January but a third (OB2021) emerged in early February 2021. The latter was deleted after the report was published.

Interestingly, some of the phishing lures appear to be specifically designed for airlines that use the BSPLink software, IATA's solution for its Billing and Settlement Plan (BSP). The hackers' lure changed recently, "to mimic a new feature recently introduced by IATA called IATA ONE ID (Contactless Passenger Processing tool)." In general, the threat actors use a variety of lures ranging from COVID-19 and Microsoft Updates to IATA security, to Canada Visa.

APT name	Regions attacked	Operation start
TA413	Global (Tibetan organizations)	January 2021

Proofpoint discovered a campaign linked to the Chinese group TA413. According to the researchers, the campaign was active in January and February 2021. The hackers attacked Tibetan organizations worldwide using FriarFox, a malicious Firefox browser extension that stole Gmail and Firefox data and then downloaded a Trojan on infected systems.

The researchers said that the attackers targeted Tibetan organizations with spear-phishing emails that lured victims to websites where they were be prompted to install a fake Flash update that was claimed to be necessary to view the site's content.

In reality, these websites contained code that separated users. Only Firefox users with an active Gmail session were prompted to install the malicious extension.

The extension was named "Flash update components," but it was actually a version of the legitimate Gmail notifier (restartless) extension, with additional malicious code. The code could abuse the following functions on infected browsers:

Gmail:

- Search emails
- Archive emails
- Receive Gmail notifications
- Read emails
- Alter Firefox browser audio and visual alert features
- Label emails
- Mark emails as spam
- Delete messages
- Refresh inbox
- Forward emails
- Perform function searches
- Delete messages from Gmail trash
- Send mail from the compromised account

Firefox (based on granted browser permissions):

- Access user data for all websites
- Display notifications
- Read and modify privacy settings
- Access browser tabs

But the attack did not stop there. The extension also downloaded and installed the ScanBox malware on infected systems. This malware is an old tool based on PHP and JavaScript, seen in previous attacks carried out by Chinese cyber-espionage groups. The last recorded case of a ScanBox attack dates back to 2019.

ScanBox can track visitors to specific websites, perform keylogging, and collect user data that can be used in future attacks.

The Chinese group TA413 has been active for roughly a decade. The group has been previously associated with malware such as LuckyCat and ExileRAT. It mainly targets the Tibetan community.

APT name	Regions attacked	Operation start
APT41	Hong Kong, India, USA, China, Russia, South Korea, Canada, Argentina, Spain, India, Taiwan, Indonesia	May 2020

January saw the discovery of a previously unknown backdoor called FunnySwitch and an attack involving it. The backdoor's droppers had a Zealot Digital digital signature, which had been used in attacks against Hong Kong. FunnySwitch is written in .NET and capable of running arbitrary JScript code and acting as a message relay between different copies of the backdoor and a C&C server. It was created by APT41 and got its name based on the name of a library and one of the key classes.

FunnySwitch is designed to collect the following information:

- Values of the registry keys ProductName and CSDVersion from HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion
- Whether the OS is 32-bit or 64-bit
- List of IP addresses
- Computer name
- Username and workgroup
- Name of the running module
- PID
- MAC addresses of network adapters
- Value of the Group attribute in the XML configuration

The attack in question starts with the SFX archive "x32.exe."

The archive unpacks three files ("1.vbs," "n3.exe," and "p3.exe") into the folder c:\programdata, after which the extracted VBS script runs both executables. The files "n3.exe" and "p3.exe" are identical and inject shellcode into the process "explorer.exe."

The backdoor starts by parsing the configuration. Its root element may contain the following fields:

- Debug is the flag for enabling debug logging
- Group is an arbitrary string sent together with system information
- Password is the key used to encrypt messages
- ID identifies the relay (if not present in the configuration, the GUID is used instead)
- StartTime, EndTime, and WeekDays restrict the times and days when the backdoor may function

Connection with the C&C server can be established in various ways:

- TCP connection (TcpConnector and TcpBindConnector), parameters: address and port (by default, 38001).
- Proxy and HTTP connection (HttpConnector and HttpBindConnector)
- Connection via a Named Pipe

For the network connectors to work, the backdoor adds an allow rule to Windows Firewall with the name “Core Networking — IPv4” for its executable module.

It was also discovered that APT41 had carried out an attack against Unity3D, a Russian game developer. An archive called “Resume.rar” was discovered; it contained a file called “CV.chm.”

Running the file without security updates installed causes two windows to appear simultaneously: CHM help in HTML Help and a PDF document. They contain the same information: a curriculum vitae (CV) for the position of game developer or database manager at a St. Petersburg company.

The CV contains plausible contact information, with a St. Petersburg address, email address ending with "@yandex[.]ru", and phone number starting with "+7" (Russia's country code). The only obviously fake aspect is the phone number: 123-45-67.

“resume.exe” is an advanced shellcode injector which has not been seen in campaigns before. Before it gets down to business, this malware, like many other samples from Winnti, checks the current year. In addition, current processes are checked.

On the first launch of “resume.exe,” the encrypted portion of the data is decrypted (the key is hardcoded in the executable) and three sections are extracted (PDF, auxiliary shellcode, and main shellcode). The payload runs in a new process, %windir%\System32\spoolsv.exe, into which the main shellcode is injected: Cobalt Strike Beacon.

Starting from March 2, 2021, APT41 compromised the email servers of an oil company and a construction equipment company both based in East Asia. The compromise resulted from the exploitation of vulnerabilities CVE-2021-26855, CVE-2021-26857, CVE-2021-26858, and CVE-2021-27065 in Microsoft Exchange Server 2013, 2016 and 2019. An investigation into the incident revealed that one of the compromised hosts had PlugX RAT installed.

In December 2020, specialists at Doctor Web conducted an investigation at a telecommunications company in Central Asia. Analysis of its infrastructure revealed an unknown backdoor, which was named Spyder because this name was used in the code. Malicious files got to the company’s computers in May 2020, it was reported, but a service called MSDTC was only created on November 23. The payload oci.dll contains the main PE module but it does not have a file signature. The module is intended for loading additional modules received from the C&C server.

In March, security specialists discovered a new Linux backdoor associated with APT41 and dubbed RedXOR. Its samples were uploaded to VirusTotal from Taiwan and Indonesia. The backdoor was a 64-bit ELF file called “po1kitd-update-k.”

Upon execution RedXOR forks off a child process allowing the parent process to exit. The purpose is to detach the process from the shell. The new child determines if it has been executed as the root user or as another user on the system. It does this to create a hidden folder called “.po1kitd.thumb” inside the user’s home folder.

The malware allows threat actors to upload or download additional files, start a reverse shell, use tunneling, and collect system information. When the malware first contacts the C&C server it sends a password encoded in the request body. The C&C server responds with the command code 0 to collect system information. The data is serialized into a URL query-like string, encrypted and then sent as the request body.

In addition, a campaign against the Indian power sector was discovered. Even though security specialists said the new group was RedEcho, we have seen a strong resemblance to the techniques and infrastructure of the Chinese group APT41. The targets of the attack include ten power sector organizations, including a power station in New Delhi, and two seaports as well as four of five Regional Load Despatch Centres (RLDC) whose disruption would have caused India’s power grid to collapse. The attack involved the ShadowPad backdoor.

APT41 (also known as WICKED SPIDER (PANDA), Winnti Umbrella, BARIUM, LEAD, Blackfly, Suckfly, and GREF) is a Chinese state-sponsored threat group whose goals are cyber espionage and financial gains. The group has been active since at least 2007. APT41 specializes in stealing digital certificates to use them in activities related to stealing user data (cyber espionage) and deploying crypto miners and ransomware on target devices. The group's earlier goals included manipulation of currencies in online games and intellectual property thefts.

APT name	Regions attacked	Operation start
SideWinder	Pakistan, China	November 2020

The SideWinder group continued its attacks against Pakistani government officials. The threat actors used a file called "NDC Participants.docx" as a lure. The payload was in a file called "main.file.rtf." Persistence is achieved through creating a scheduled task.

In addition, LNK files attributed to SideWinder were found at different times.

The file acted as a loader for a next-stage module. For the initial launch of the modules ("Duser.dll" loaded by a legitimate module "rekeywiz.exe"), a scheduled task called UpdateService is used. The modified library has appeared more than once.

In terms of exports there are mainly three functions:

- FileRipper
- Gadgets
- InitGadgets

Other variants containing an extended list of exportable functions also exist:

- FileRipper
- Gadgets
- InitGadgets
- PSCreateMemoryPropertyStore

The SideWinder group (also known as Rattlesnake, Hardcore Nationalist (HN2), T-APT-04, and APT-C-17) has been active since at least 2012. The group engages in cyber espionage against targets in South Asian government entities (governments, the military). The group's attacks target both Windows and Android users.

APT name	Regions attacked	Operation start
Gamaredon	Ukraine	2020

In January, a template file called KzGdWvmSq[.]dot was discovered. Presumably, the file was loaded by a decoy document according to an attack scheme that has lately been typical of the group. The script is designed for creating the main payload file by iteratively writing Base64-encoded data to a text file. This file's location path is %USERPROFILE%\PrintSoftware\PrintDriver.vbs.

Later, another such document was discovered. When launched for viewing, a malicious .dot template was downloaded from a third-party resource. The template contained a VBA script that formed a new script with the main payload and disabled security settings related to running macros.

By using the created script, the legitimate file "Wscript.exe" is copied to a file called "PrintDriver.exe." Next, instructions are written to the file of a resident script, called "PrintDriver.vbs," in the form of Base64-encoded data.

Decoding and deobfuscating the script revealed that its functionality included:

1. Persistence through the registry
2. Obtaining information about the processor and BIOS, disk drive serial number, and user name.
3. Creating a URI from the collected data to send a signal to the C&C server and subsequently enter sleep mode.

Beacon packets are sent through GET requests to a domain registered by the attackers, with information about BIOS being included in the URI. In addition, packet HTTP headers transfer the disk drive serial number and host name, which was used earlier in the URI when sending beacon packets.

The threat actors were seen using trojanized applications again. In their attack, launching an installer file creates two processes: malicious module launch and the launch of a legitimate Zoom installer.

The first stage is a Windows batch file that creates a VBS file. The VBS will only exfiltrate the C drive serial number and there is no retry mechanism, nor is there a sleep time.

The script then creates a scheduled task that runs every 14 minutes. When the task starts, a request with collected information about the system is sent to the C&C server; in response, the server returns second-stage payload, which was not available at the time of the analysis.

Gamaredon Group (also known as Primitive Bear and SectorC08) is presumably a Russian threat group active since at least 2013. The group aims to spy on Ukrainian government officials, the military, diplomats, law enforcers, and, in recent campaigns, journalists. There is also information about Gamaredon Group's links with the EvilGnome group, which attacks Linux desktops.

APT name	Regions attacked	Operation start
HAFNIUM	USA, Germany, Canada, France, Uzbekistan, Bangladesh, Belgium, Hong Kong, Italy, Kazakhstan, South Korea, Turkey, UAE, Slovenia, Pakistan, Mongolia, Israel, Guyana, Brazil, Russia, South Africa, Mauritius	January 2021

Microsoft detected multiple zero-day exploits being used to attack on-premises versions of Microsoft Exchange Server in limited and targeted attacks. In the attacks observed, the threat actors used these vulnerabilities to access on-premises Exchange servers which enabled access to email accounts, and allowed installation of additional malware to facilitate long-term access to victim environments. Microsoft Threat Intelligence Center (MSTIC) attributes this campaign with high confidence to HAFNIUM, a group assessed to be state-sponsored and operating out of China, based on observed victimology, tactics and procedures.

- CVE-2021-26855 is a server-side request forgery (SSRF) vulnerability in Exchange which allowed the attackers to send arbitrary HTTP requests and authenticate as the Exchange server.
- CVE-2021-26857 is an insecure deserialization vulnerability in the Unified Messaging service. Exploiting this vulnerability gave HAFNIUM the ability to run code as SYSTEM on the Exchange server. This requires administrator permission or another vulnerability to exploit.
- CVE-2021-26858 is a post-authentication arbitrary file write vulnerability in Exchange.
- CVE-2021-27065 is another post-authentication arbitrary file write vulnerability in Exchange.

Experts noticed that the threat actors focused on obtaining emails from the target mailbox.

After exploiting these vulnerabilities to gain initial access, HAFNIUM operators deployed web shells on the compromised server. Web shells potentially allow attackers to steal data and perform additional malicious actions that lead to further compromise.

Security experts noted that the hackers used several web shells, such as China Chopper and ASPXSPY.

The experts also identified the following utilities on the compromised systems:

- Procdump
- Nishang
- PowerCat
- Psexec
- Mimikatz

The group initially focused on attacking various organizations in the US, but early March saw major targets that suffered this attack method in other countries. For instance, the European Banking Authority and the Chilean Financial Market Commission (Comisión para el Mercado Financiero) were among the targets.

We would like to note that the ProxyLogon vulnerability is currently used by multiple groups, both state-sponsored and cybercrime-focused. We recommend installing the latest updates for Microsoft Exchange servers as soon as possible!

APT name	Regions attacked	Operation start
Lazarus	Global, Russia	May 2020

On January 20, 2021, a new loader by Lazarus was discovered. The group had earlier employed phishing with macro documents disguised as job descriptions (via LinkedIn).

The decoy document purported to be Northrop Grumman Corporation job instructions. Northrop Grumman Corporation (NYSE: NOC) is an American multinational aerospace and defense technology company. With 90,000 employees and an annual revenue in excess of $30 billion, it is one of the world's largest weapons manufacturers and military technology providers.

After analyzing the macro document and pivoting on the macro, researchers identified a number of other similar documents. In these documents, they came across an interesting technique being used to execute shellcode from VBA without the use of common “suspicious” APIs, such as VirtualAlloc, WriteProcessMemory or CreateThread — which may be detected by endpoint protection solutions. Instead, the macro documents abuse “benign” Windows API features to achieve code-execution.

It was found that the hackers had targeted the defense industry using phishing emails that claimed to have urgent updates on today’s hottest topic – COVID-19 infections. The phishing emails were carefully crafted and written on behalf of a medical center that is part of the organization under attack.

The attackers registered accounts with a public email service, making sure the sender email addresses looked similar to the medical center’s real email address. The signature in the phishing emails included actual personal data of the deputy head doctor of the attacked organization’s medical center.

Upon opening a malicious document and allowing the macro, the malware is dropped and proceeds to a multistage deployment procedure. The malware used in this campaign belongs to a known malware cluster we named ThreatNeedle. Researchers attribute this malware family to the advanced version of Manuscrypt (a.k.a. NukeSped).

The final payload executed in memory is the actual ThreatNeedle backdoor. It has the following functionality to control infected victim machines:

- Manipulate files/directories
- System profiling

- Control backdoor processes
- Enter sleeping or hibernation mode
- Update backdoor configuration
- Execute received commands

In addition, in Q1 2021, Lazarus carried out a campaign targeting security researchers working on vulnerability research and development at different companies and organizations.

In order to build credibility and connect with security researchers, the actors established a research blog and multiple Twitter profiles to interact with potential targets. They used these Twitter profiles for posting links to their blog, posting videos of their claimed exploits and for amplifying and retweeting posts from other accounts that they controlled.

The actors have been observed targeting specific security researchers by a novel social engineering method. After establishing initial communication on Twitter, the actors asked the target to switch to Telegram and in the end sent an encrypted gpg project.

The security researchers were compromised after visiting the threat actors' blog. In each of these cases, the researchers followed a link on Twitter to a write-up hosted on blog.br0vvnn[.]io, and shortly thereafter, a malicious service was installed on the researcher's system and an in-memory backdoor would begin beaconing to an actor-owned C&C server.

Experts suspect that Lazarus used vulnerability CVE-2021-26411 in Edge and Internet Explorer. It enables a hacker to perform remote code execution (RCE) when a user visits a malicious website. The hackers also used CVE-2021-21148, which is due to a heap buffer overflow flaw in Google's V8 JavaScript rendering engine.

In some cases, after establishing initial communications, the actors would ask the targeted researcher if they wanted to collaborate on vulnerability research together, and then provide the researcher with a Visual Studio Project. Within the Visual Studio project would be source code for exploiting the vulnerability, as well as an additional DLL that would be executed through Visual Studio build events. The DLL is custom malware that would immediately begin communicating with actor-controlled C2 domains.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, Guardians of Peace, and BeagleBoyz) is a cybercriminal group active since 2007. Specialists have established that the group's members are from North Korea.

APT name	Regions attacked	Operation start
Mustang Panda	USA, Europe, South-East Asia, Germany, Vietnam, India	2020

Security experts released a report about a hacking campaign dubbed Operation Dianxun, conducted by Chinese APTs against telecommunications companies in Asia, Europe, and the United States.

The TTPs used in the campaign are similar to those used by the Chinese APTs Mustang Panda and RedDelta. The latter may be a unit within the former, since its activity was discovered only in 2020 and its TTPs are similar to those of MustangPanda except for the method of encrypting traffic between malware and its C&C server.

The targets in the operation, which has been carried out since August 2020, include employees of telecommunications companies; the threat actors' focus is on 5G technology–related information.

The initial vector is not perfectly clear, but the researchers believe it is likely a phishing website masquerading as the Huawei company career page that the hackers control and use to distribute malware.

The experts discovered malware disguised as Flash applications. A sample masquerading as a Flash application used the malicious domain name flach.cn, which was made to look like the official web page for China to download the Flash application, flash.cn. The malware, among other things, downloaded the Cobalt Strike attack kit on compromised systems.

Mustang Panda (also known as HoneyMyte, Red Lich, Temp.Hex, and BRONZE PRESIDENT) is a Chinese threat group active since at least April 2017. Its main targets are governmental and non-governmental organizations and national minorities.

APT name	Regions attacked	Operation start
DarkHalo	USA, Global	2019

In January 2021, security researchers discovered Sunspot, a tool that was used in a supply-chain campaign by the DarkHalo group to inject the Sunburst backdoor into the SolarWinds Orion Platform. Sunspot monitors running processes for those involved in the compilation of the Orion product and replaces one of the source files to include the Sunburst backdoor code. To ensure persistence, a scheduled task is created. Errors and other malware deployment information are stored in a log file and log entries are encrypted using RC4. Sunspot then grants itself debugging privileges by modifying its security token to add SeDebugPrivilege. This step is a prerequisite for the remainder of Sunspot's execution, which involves reading other processes' memory. The malware monitors running processes for instances of MsBuild.exe. Copies of MsBuild.exe are identified by hashing the name of each running process and comparing it to the corresponding value, 0x53D525. When Sunspot finds an MsBuild.exe process, it will spawn a new thread to determine if the Orion software is being built and, if so, hijack the build operation to inject Sunburst. As a result, Sunburst will be compiled as part of the standard process. Sunspot adds an entry in the log file with the date of the backdoor compilation.

In March 2021, security researchers discovered three new pieces of malware (GoldMax, Sibot, GoldFinder), which were used by the DarkHalo group in the later stages of their supply-chain campaign at least from August to September 2020.

- GoldMax is a backdoor written in GO. It reads the built-in or local configuration file, exchanges data with its C&C server through HTTPS, and supports commands, including remotely updating its configuration, uploading/downloading files, and executing arbitrary commands.
- Sibot is a dual-purpose malware implemented in VBScript. It is designed to achieve persistence on the infected machine then download and execute a payload from a remote C&C server. The compromised website used to host the payload is different for every compromised network and includes websites of medical device manufacturers and IT service providers. The researchers observed three variants of this malware: the first variant involves the registry, the second involves a scheduled task to run a second-stage script, and the third variant is a standalone version of the second-stage script designed to run from a file. The purpose of the second-stage script is to download and run a payload from a remote server.
- GoldFinder is another tool written in Go. GoldFinder is used as a custom HTTP tracer tool that logs the route or hops that a packet takes to reach a hardcoded C&C server. When launched, the malware issues an HTTP request for a hardcoded IP address and logs the HTTP response to a log file. When launched, GoldFinder can identify all HTTP proxy servers and other redirectors such as network security devices that an HTTP request travels through inside and outside the network to reach the intended C&C server. When used on a compromised device, GoldFinder can be used to inform the actor of potential points of discovery or logging of their other actions, such as C&C communication with GoldMax.

DarkHalo has been active since at least 2019. The group carried out a global supply-chain attack against the customers of SolarWinds by creating a trojanized version of a software update, which was named sunburst.

APT name	Regions attacked	Operation start
Spiral	USA	2018

In 2020, security researchers discovered that in addition to DarkHalo's malware, a web shell called SuperNova was deployed in SolarWinds's network. In March 2021, this activity was attributed to the Chinese group Spiral.

In 2020, the threat actors exploited vulnerability CVE-2020-10148 to execute a reconnaissance script and then write the SuperNova web shell to disk using PowerShell. SuperNova is written in C# and is a trojanized version of a legitimate DLL ("app_web_logoimagehandler.ashx.b6031896.dll") used by the SolarWinds Orion Platform. The threat actors obtained credentials by dumping the content of the LSASS process using the legitimate library "comsvcs.dll." The obtained reconnaissance information and credentials were saved to a .txt file, which if deleted from disk after being obtained by the threat actors. The threat actors' goal was to access sensitive business information.

Earlier in 2020, another intrusion into the network of Solarwinds was discovered. The intrusion, based on similarities, was attributed to Spiral. Security researchers' investigation revealed that the intruders gained access to the network as far back as 2018 using a vulnerability in a ManageEngine ServiceDesk server and used this access to periodically harvest and exfiltrate domain credentials. In August 2020, the attackers stole credentials and used them to access files from Microsoft Office 365-hosted SharePoint and OneDrive services.

Spiral is a Chinese APT group, which was discovered in 2021 and has been active since at least 2018. The attack against Solarwinds involving the SuperNova web shell (which was carried out at the same time as the large-scale supply-chain campaign by the DarkHalo group against the same target) is attributed to Spiral.

APT name	Regions attacked	Operation start
A41APT (presumably, APT10)	Japan	March 2019

In January 2021, security researchers discovered a campaign against Japan that A41APT started in March 2019. Analysis revealed a strong connection with the APT10 group.

The attack can be broken down into several stages. An initial intrusion was achieved through hijacking sessions to enter the internal network via SSL-VPN or using credentials that the attackers had stolen earlier.

The second stage involved a port scan to search for an open RDP or SMB port. Then, the threat actors used an administrator account to deploy RDP to servers with free RDP.

To steal credentials, the threat actors used CSVDE, AdFind, and dump of SYSTEM/SECURITY/SAM.

The actors use the DLL side-loading technique to load the DESLoader malware; to ensure persistence, they use a scheduled task. DESLoader is a multilayer loader for payloads such as SodaMaster, P8RAT, CobaltStrike stager shellcode beacon, and FYAntiLoader (the latter loads .NET Loader(ConfuserEx v1.0.0), which in turn loads xRAT).

- SodaMaster (aka DelfsCake, dfls, HEAVYPOT) is a fileless RAT; communication with the server is encrypted.
- P8RAT (aka GreetCake) is a fileless RAT; about 300 command identifiers, with the main feature being the execution of secondary PE based payload downloaded into memory.
- FYAntiLoader is a fileless loader containing .NET Loader packed with ConfuserEx v1.0.0. The final payload is xRAT.

APT10 is a Chinese cybercriminal group active since at least December 2009. The group carries out attacks to primarily spy on construction, engineering, aerospace, telecommunications, and government organizations. Japanese organizations have been affected the most.

APT name	Regions attacked	Operation start
Cloud Atlas	Ukraine, Belarus, Russia, Uzbekistan, France	2019

Security specialists discovered a campaign, which dates back to at least 2019 and is attributed to the Cloud Atlas group. Based on the indicators of compromised and detected infrastructure, the main focus of the attacks is still on the Commonwealth of Independent States (CIS), but there is also some targeting against Western Europe.

The specialists discovered a pattern, according to which the threat actors created infrastructures for their attacks. Analysis revealed additional, previously unknown network indicators and related files. The discovered files were on various topics and had the following names:

- Личные данные Алмаз.doc
- DRAFT Concept Paper EEC 10 March 2021.doc
- FORM-0-COVID-19.doc
- Таможенное регулирование на предприятии.doc
- EUISS Reflection Paper - CSDP.doc
- Методика профкультуры_госорганы.doc
- AL-Qaeda's external operations.doc
- ЕАЭС интеграционные процессы.doc
- Минтруд госслужба.doc
- Strategic Defence and Security Review (2021 SDSR).doc
- Справочник АП_26.10.2020_.doc
- PKK militants in Nagorno-Karabakh.doc
- Новые поправки к Госпрограмме переселения в РФ (вст. в силу 01.07.2020).doc
- C. Bayramov.doc
- Scandal that killed 346 people.doc
- Планируемые расходы 2020(1).doc
- О поставке зенитных ракетных систем С-400.doc
- Фадеев М1.doc

The documents attempt to retrieve and execute an external payload for follow-on execution via PowerShell or VBScript. While the majority of the identified samples continue to leverage remote template retrieval via HTTPS, several samples also included Server Message Block (SMB).

Cloud Atlas is a Russian threat group whose primary goal is espionage. The threat is a continuation of the RedOctober operation launched in 2012. The group's attacks mainly target industries and government entities in Russia and the CIS.

APT name	Regions attacked	Operation start
Turla	-	August 2020

In February 2021, information about a new tool of the Turla group emerged. The tool was named IronNetInjector. Security researchers discovered several IronPython scripts, whose purpose was to load and run Turla's malware tools on a victim's system. IronNetInjector is mostly used to load ComRAT. There were also cased of the RPC backdoor and another payload being used. The attackers applied a method known as Bring Your Own Interpreter (BYOI).

IronNetInjector is made of an IronPython script that contains a .NET injector and one or more payloads. When an IronPython script is run, the .NET injector gets loaded, which in turn injects the payload(s) into its own or a remote process.

The specialists found two versions of the .NET injector, a newer variant compiled in 2019 and an earlier variant compiled in 2018. The earlier variant is much more limited in functionality compared to the newer variant. Both versions are full-blown PE injection tools able to load payload into a remote process.

Turla is a Russian-speaking cybercriminal group believed to have been active since 2007. The main goal of Turla's attacks is to steal information from diplomatic, government, military, educational, research, and pharmaceutical organizations.

APT name	Regions attacked	Operation start
APT28	Kazakhstan	February 2021

In February, files that had apparently been used in APT28 attacks against Kazakhstan were uploaded to VirusTotal. The decoys were in Russian and some of them were disguised as an internal document by Kazchrome, a mining and metals company.

The files contained a malicious macro. After it is run, an executable is loaded, which creates a keystroke event handler. In addition, connection with a C&C server is established, which is used for uploading keystroke data and obtaining further commands. The malware used in the attack is a version of Downdelph.

A number of instructions are sent from the server:

- Continue uploading keystroke data
- Execute a command in a command line interpreter and load the result
- Set the timeout to two minutes
- Set the timeout to 30 minutes
- Create a screenshot and upload the result
- Terminate the execution

APT28 is a Russian-speaking cybercriminal group active since 2004. Most of the group's attacks have targeted political and military organizations, and, to a lesser extent, media outlets and sports organizations.

APT name	Regions attacked	Operation start

Presumably APT27	-	2020

In December 2020, when responding to an incident in which several servers were encrypted, security specialists discovered malware samples that had overlaps with samples from a DRBControl campaign.

APT27 or Winnti is believed to be behind the DRBControl campaign, which was carried out in 2019 and 2020. The recently discovered campaign involved a similar backdoor, which was dubbed Clambling.

Access to the victim company was gained through a compromised service provider. An ASPXSpy web shell was deployed to assist in lateral movement. PlugX and Clambling samples were loaded into memory using the DLL side-loading technique. In addition, on the infected machine the specialists discovered Mimikatz and a file used for escalating privileges by exploiting CVE-2017-0213. The researchers note a strong link to the APT27 group in terms of code similarities and TTPs.

Clambling has features such as keylogging, screen capturing, managing files, working with commands, and collecting system information. Persistence is set up through the system services if the sample has the correct privileges, otherwise it utilizes the Run registry key. The sample contained three protocols for C&C communication: UDP, TCP, and HTTP. After a certain command, traces of the threat actors' presence are removed from the infected machine, including added registry keys, services, and files involved in the attack.

APT27 is a Chinese cybercriminal group known since 2010. The group targets aerospace, government, defense, technology, energy, and manufacturing industries. It has recently started actively using ransomware in their attacks, with a focus on financial gain.

APT name	Regions attacked	Operation start
APT-C-35	-	March 2021

In March 2021, another Donot Android Trojan sample, called "Omgle_v2n.apk," was uploaded to VirusTotal. Presumably, the threat actors attempted to disguise it as Omegle, a chat app. A domain registered in late January 2021 was used as a C&C server.

The Trojan can perform the following actions, which are received from the C&C server:

- Call — obtain a list of calls and save it to "CallLogs.txt"
- CT — obtain a list of contacts and save it to "contacts.txt"
- SMS — obtain text messages and save them to "sms.txt"
- Key — obtain keystrokes and save them to "keys.txt"
- Tree — obtain a list of SD card files and save it to "Tree.txt"
- AC — obtain accounts and save them to "accounts.txt"
- Net — obtain network information and save it to "netinfo.txt"
- CR — configure call recording
- LR — configure a recording period
- FS — upload files
- GP — receive GPS data and save it to "GP.txt"
- PK — obtain a list of what is installed and save it to "pkinfo.txt"
- BW — obtain browser information and save it to "bw.txt"
- CE — obtain calendar information and save it to "ce.txt"
- Wapp — obtain information from WhatsApp and save it to "WappHolder.txt"

APT-C-35 (also known as Donot Team and SectorE02) is a South Asian threat group presumably based in India and active since 2016. The goal of the group's attacks is espionage and information theft mostly

against Pakistani targets. The hackers' arsenal includes tools for attacks on Windows and Android; the threat actors periodically update them to make their detection less likely.

APT name	Regions attacked	Operation start
APT35	USA, Europe, Middle East	December 2020

In late 2020, the APT35 group carried out targeted attacks during Christmas and New Year holidays against think tank members, a political research center, university professors, journalists, and environmental activists from the Gulf States, Europe and the US. The campaign involves spear-phishing emails sent to victims' personal (Gmail, Yahoo!, Outlook) and business (organizations and universities) email addresses. Once the threat actors gain access to credentials, they steal confidential data of their victims.

In this campaign, the threat actors used two vectors:

- Sending fake SMS messages
- Sending phishing emails

The Iranian threat group APT35 (also known as Phosphorus, Charming Kitten, Ajax Security Team, Newscaster, Group 83, and Parastoo) has been carrying out attacks since at least 2013. The group focuses on individuals of interest to Iran who work in the fields of academic research, human rights, and media, with most victims located in Iran, the United States, Israel, and the UK.

APT name	Regions attacked	Operation start
BlackEnergy	France	2017

According to ANSSI, the BlackEnergy group carried out attacks targeting the French IT monitoring software manufacturer CENTREON, which resulted in the breach of several French entities.

The first victim seems to have been compromised from late 2017. The campaign lasted until 2020. This campaign mostly affected information technology providers, especially web hosting providers. On compromised systems, ANSSI discovered the presence of a backdoor in the form of a web shell dropped on several Centreon servers exposed to the Internet. This backdoor was identified as being the P.A.S. web shell, version number 3.1.4. On the same servers, ANSSI found another backdoor identical to one described by ESET and named Exaramel. According to ANSSI, this campaign bears several similarities with previous campaigns attributed to the Sandworm group.

Exaramel was found in the Centreon server folder either at /usr/share/centreon/www/ or at /usr/local/centreon/www/modules/. In the same folder, several other files were found including a script named respawner[.]sh and configuration files "config.json" and "configtx.json," as well as several files named with a number followed by the .rep extension. Logs indicating daily execution of respawner[.]sh by CRON were observed from November 2017 to February 2018. The researchers could not retrieve its content and its role is thus unknown. All Linux/Exaramel-related files analyzed by ANSSI were created by the apache user.

The Exaramel backdoor supports the following commands:

- App.Delete — Exaramel self-deletes. It uninstalls the persistence and deletes its configuration file.
- App.SetServer — adds a server URL to the configuration field Hosts. The new URL is added at the beginning of the list.
- App.SetProxy — sets a new value for the configuration field Proxy.

- App.SetTimeout — sets a new value for the configuration field Timeout.
- App.Update — downloads a file from the C&C server, replaces the current binary with it, runs it, and halts itself.
- IO.ReadFile — copies a file from Exaramel host to the C&C server.
- IO.WriteFile — copies a file from the C&C server to Exaramel host.
- OS.ShellExecute — runs a shell command and sends a copy of both standard and error output to the C&C server.

The BlackEnergy group has been active since at least 2010. The group's activity is closely linked with the use of the BlackEnergy malware, developed in 2007 by a hacker with the nickname Cr4sh. After its source code was sold, improvements were made. It was noted that the group's targets were either infrastructures, whose disruption resulted in massive damages, or organizations with access to strategic data that could be used by the threat actors for their own ends. The group's arsenal includes malware such as BlackEnergy, Industroyer, GreyEnergy, BadRabbit, and VPNFilter.

APT name	Regions attacked	Operation start
MuddyWater	UAE, Saudi Arabia, Azerbaijan, Bahrain, Israel	End of 2020

Starting from late 2020, the MuddyWater group carried out attacks against targets in the Middle East and neighboring regions. In this campaign, the threat actors used spear-phishing emails with embedded links to legitimate services (ScreenConnect and RemoteUtilities) to distribute their malicious package. The links were embedded within lure documents as well as emails. Once a victim was accessed, the attackers would then download post-exploitation tools that included password/process-dumping utilities, reverse-tunneling tools, and custom backdoors.

In one attack, security researchers observed a spear-phishing email allegedly from a government agency. The lure documents' content attempts to convince the victim to click on another malicious URL and download a .zip file. The .zip file contains a copy of legitimate remote administration software developed by RemoteUtilities and provides remote administration capabilities, including:

- Downloading and uploading files
- Grabbing screenshots
- Browsing files and directories
- Executing and terminating processes

In addition, the researchers discovered a compromised host in Saudi Arabia that used the ScreenConnect remote administration software. The victim was targeted via a malicious .zip file. To ensure persistence on compromised devices, the threat actors used commands that loaded .js files from the Programs\Startup directory upon system startup.

The loaded "newsblog.js" is a VBS downloader that communicates with the following URL: hxxp://23[.]95[.]215[.]100:8008/index.jsp/7e95a3d753cc4a17793ef9513e030b49/4t2Fg7k6wWRnKgd9. The script executes an HTTP GET request to the C&C server, grabs the server's response, and sleeps for ten seconds. The response from the server contains an encoded PowerShell script, which is executed in memory. Decoding this script reveals that it contains a backdoor.

The PowerShell backdoor has the following capabilities:

- Check for Skype connectivity
- Download and install Skype
- Encoded communication with its C&C server
- Execute commands sent from the C&C server

- Get multifactor authentication settings
- Get the currently logged-on user and OS version

MuddyWater is a cybercriminal group active since 2017 mostly in the Middle East. The group's main activity is cyber espionage in pursuit of Iran's interests. The threat actors' targets are government agencies and organizations, military entities, and petrochemical and telecommunications companies. The targets are located in Saudi Arabia, the UAE, the US, Israel, Iraq, India, Jordan, Egypt, Tunisia, Turkey, Tajikistan, Iran, Belarus, Russia, Uzbekistan, Georgia, and Pakistan. Most of the victims are in the Middle East.